ResearchGate

See discussions, stats, and author profiles for this publication at: https://www.researchgate.net/publication/395964317

Bridging the human factor gap: Fortifying employees through training, culture, and behavioral intervention

Thesis · April 2025

DOI: 10.13140/RG.2.2.22786.95683

CITATIONS
0

READS
33

1 author:

Michael Babcock
American Military University

1 PUBLICATION **0** CITATIONS

SEE PROFILE

All content following this page was uploaded by Michael Babcock on 29 September 2025.

The user has requested enhancement of the downloaded file.

BRIDGING THE HUMAN FACTOR GAP: FORTIFYING EMPLOYEES THROUGH TRAINING, CULTURE, AND BEHAVIORAL INTERVENTION

A Master Thesis

Submitted to the Faculty

of

American Military University

by

Michael James Babcock

In Partial Fulfillment of the

Requirements for the Degree

of

Master of Science in Information Technology

April 2025

American Public University System

Charles Town, WV

The author hereby grants the American Public University System the right to display these contents for educational purposes.

The author assumes total responsibility for meeting the requirements set by United States copyright law for the inclusion of any materials that are not the author's creation or in the public domain.

© Copyright 2025 by Michael James Babcock

All rights reserved.

DEDICATION

I hereby dedicate this thesis to my wife and daughters, who have supported me throughout this journey, offering unwavering encouragement and grace. Their support made every milestone possible, reminding me that no academic pursuit is greater than the love and patience they give so freely.

ACKNOWLEDGMENTS

I wish to thank Dr. Glenda Holcomb for her expert guidance and unwavering support throughout the development of this thesis. Her guidance helped me navigate difficult moments and deepened my understanding of the research process. I would also like to express my gratitude to all the security practitioners who work tirelessly to safeguard our information. Their vigilance makes it possible to pursue new ideas with confidence and peace of mind.

TABLE OF CONTENTS

COPYRIGHT PAGE……...…2

DEDICATION…….....…....3

ACKNOWLEDGMENTS…….……..4

ABSTRACT……...….9

CHAPTER PAGE

I. INTRODUCTION 10

Background of the Problem 10

Statement of the Problem.....11

Statement of the Purpose 12

Research Questions 12

Significance of the Study 13

Definition of Unclear Terms 13

Limitations, Delimitations, and Assumptions 15

II. LITERATURE REVIEW 16

Theoretical Foundations for Security-Related Behavior 17

Traditional vs. Interactive Cybersecurity Training 20

Organizational Culture and Security Policy Compliance 24

Sustained Behavioral Interventions to Reduce Security Incidents 28

Persistent Challenges and Research Gaps..... 33

Conclusion of the Literature Review 38

III. METHODOLOGY 41

Subjects and Setting 41

Data Collection Technique 41

Statistical Analysis 42

Hypotheses 42

Limitations of the Study 43

IV. RESULTS 44

Overview of Data Sources and Methodological Context 44

Theoretical Perspectives and Observed Behaviors 45

Overview of Data Organization 47

RQ1: Comparing Interactive, Targeted Training with Traditional, Generic Training. 48

RQ2: How Organizational Culture and Norms Influence Policy Compliance 52

RQ3: Effectiveness of Sustained Behavioral Interventions in Reducing Incidents.... 56

Synthesis Across All Three Research Questions 59

Limitations and Caveats 63

Conclusion of the Results 65

V. DISCUSSION 65

Overview of the Discussion 66

Addressing Research Question 1 67

Addressing Research Question 2 69

Addressing Research Question 3 70

Interpretation of the Results 71

Theoretical and Practical Implications 72

Evaluating the Hypotheses 74

Limitations and Caveats 75

Conclusion of the Discussion 76

VI. FINDINGS 78

RQ1: The Efficacy of Targeted Cybersecurity Training 78

RQ2: The Role of Cultural Alignment in Policy Compliance 79

RQ3: The Necessity of Sustained Behavioral Reinforcement 80

Recommendations for Future Research 81

Conclusion Of the Findings 88

VII. LIST OF REFERENCES 90

VIII. APPENDICES 97

Appendix A: Human-Centric IS and Cybersecurity Resilience Framework 97

Appendix B: Framework for Auditing IS and Cybersecurity Culture 106

Appendix C: Permission to Quote or Reproduce Copyrighted Material 121

Appendix D: Thesis Approval Document 122

LIST OF TABLES

TABLE PAGE

1. Theoretical Foundations and Related Secure Behaviors……..…..……47
2. Comparison of Targeted Interactive and Traditional Generic Training Methods.…….50
3. Comparison of Aligned and Misaligned IS and Cybersecurity Policies…….…..……..53
4. Comparison of Sustained and Short-term or No Interventions…….….……56
5. Summary of Key Findings by Research Question…..……..…..……60
6. Cross-Industry Reported Impacts on the Human Factor Gap…….…….……..61
7. Empirical Findings from Key Studies…….….…….….62
8. Outcomes of Key Cybersecurity Interventions across Different Industries….……66

ABSTRACT OF THE THESIS

BRIDGING THE HUMAN FACTOR GAP: FORTIFYING EMPLOYEES THROUGH TRAINING, CULTURE, AND BEHAVIORAL INTERVENTION

by

Michael James Babcock

American Public University System, April 20, 2025

Charles Town, West Virginia

Dr. Glenda Holcomb, Thesis Professor

This thesis investigates how targeted, interactive training, culturally aligned policies, and sustained behavioral interventions collectively enhance employee compliance with information systems and cybersecurity policies and procedures. By examining case studies, theoretical frameworks, and statistical data, this study addresses three questions: whether interactive targeted training surpasses generic training sessions in reducing employee-related security incidents, how culturally aligned security policies foster higher policy compliance, and to what extent continuous behavior reinforcement mitigates employee alert fatigue and complacency. The findings reveal that context-specific, immersive training methods significantly strengthen user vigilance, that leadership modeling and cultural alignment reduce workarounds, and that regular interventions sustain attention without overwhelming staff. Despite resource limitations and an ever-evolving threat landscape, the results underscore that a strategically coordinated, human-centric approach is essential to closing the human factor gap between technical safeguards and employees' day-to-day practices. Recommendations for future research include long-term, cross-cultural, and cost-effectiveness studies to achieve broader organizational impact.

Keywords: Cybersecurity Training, Policy Compliance, Human-Centric Security

INTRODUCTION

Background of the Problem

In today's digital landscape, organizations are often tempted to focus on the latest detection algorithms, multifactor authentication, and encryption methods to protect their information systems (IS). However, security incidents repeatedly show that an unintentional click on a malicious link, made by an employee facing a tight deadline, can nullify even the most sophisticated technical safeguards (Anant et al., 2020; Shah et al., 2023). This persistent gap between cutting-edge technology and ordinary human behavior underscores a fundamental truth: IS and cybersecurity outcomes are only as strong as the employees behind them (Campean, 2019).

Despite the existence of advanced controls with real-time threat protection, analytics, and sophisticated detection algorithms, employees are often regarded as the weakest link due either to ignorance, time-pressured workarounds, or complacency in following security procedures (Shah et al., 2023). As many IS and cybersecurity data breaches and other security-related incidents have demonstrated, bridging the gap between highly sophisticated technological controls and employee actions is the key to achieving a unified and effective security posture (Campean, 2019).

Recent research indicates that the most effective way to enhance employee security behaviors is by improving how organizations deliver security information, no longer relying on the same traditional methods that have been used for decades. This means providing targeted training that enlightens and engages, alongside security policies that inform, reflect, and reinforce organizational culture to enable secure behaviors (Alohali et al., 2018; Amankwa et al., 2022; Jansen & van Schaik, 2018). Additionally, enforcing and reinforcing training and policies

creates the opportunity to enhance employee security behaviors and the overall security culture of the organization. Organizations should focus on positive reinforcement rather than punishment of undesirable behavior to accomplish effective reinforcement. Studies indicate that organizations employing a layered approach, such as this, to IS and cybersecurity enablement, encompassing training, cultural alignment, and targeted interventions, are better equipped to respond to the latest cyber threats. (Przymus et al., 2024). Without a sustained effort to maintain human-centric security measures at the same level as technical innovations, weaknesses in user behavior will continue to undermine even the most advanced defenses, jeopardizing critical infrastructure and sensitive information alike (Przymus et al., 2024).

Statement of the Problem

Although a significant body of research has addressed the human factor in IS and cybersecurity, much of this relies on out-of-date or overly generic training methods that fail to account for today's diverse workforce and the wide variety of operational environments in which they operate (Donkeal Chandrashekar et al., 2024). Studies repeatedly emphasize that employees remain the primary contributors to IS and cybersecurity-related incidents and data breaches (Willison & Warkentin, 2013), with real-world analyses confirming this finding across multiple industries (Amankwa et al., 2022; Reddy & Dietrich, 2017). Additionally, one comprehensive review reported that over half of cyberattacks went undetected for an average of 99 days, indicating how rapidly evolving threats can exploit the persistent gap between advanced technical mechanisms and employee vigilance (Georg-Schaffner & Prinz, 2022).

Specifically, phishing remains a particularly prevalent form of malicious activity, with over 500 million known incidents reported in 2022 alone (Main & Bottorff, 2023). A disconnect between new training technologies and a broader organizational reluctance to retire outdated,

“one-size-fits-all” instructional models have intensified the human factor gap (Alnajim et al., 2023; Haney & Lutters, 2020).

As a result, there is a critical need for training that is adaptive, interactive, and strategically supported and reinforced. Training that reflects the realities of modern cyber threats and encourages lasting changes in employee behavior. Without these targeted interventions, many organizations will remain vulnerable to increasingly sophisticated phishing campaigns and other emerging and evolving attacks. Attacks that can incubate undetected for weeks or even months, undermining the resilience of the organization’s entire IS infrastructure (Haney & Lutters, 2020; Shah et al., 2023).

Statement of the Purpose

The purpose of this study is to identify a solution for resolving the vulnerability caused by the gap that exists between the technical safeguards of an IS and the behavior of its users. This research sought to identify and validate the need for customized security training methods that connect policy expectations with user conduct and build a more comprehensive human-centric IS and cybersecurity strategy. Furthermore, it will develop and propose two frameworks, one for implementing a human-centric security strategy and another for assessing an organization's IS and cybersecurity culture, both based on the findings of this study. Through targeted training, culturally aligned policies, and sustained behavioral interventions, organizations can mitigate employee vulnerabilities while ensuring operational efficiencies.

Research Questions

Based on the issues outlined above, the following research questions directed this study. These questions reflect the complex nature of employees' roles in IS and cybersecurity strategies.

They investigate the effectiveness of training in raising awareness and how organizational culture and behavioral interventions shape the lasting impact of such programs.

- **RQ1:** How does interactive, targeted cybersecurity training compare to traditional, generic training in improving employee awareness and secure behaviors?
- **RQ2:** How do information security policies aligned with organizational culture and norms influence user compliance and reduce security policy violations?
- **RQ3:** How effective are sustained behavioral interventions at decreasing employee-related security incidents?

Significance of the Study

Despite advancements in technical safeguards, employees continue to undermine even the most sophisticated security systems through unintentional errors, policy non-compliance, and deliberate circumvention of security protocols (Jansen & van Schaik, 2018). IS and cybersecurity incidents stem from human behavior in over 85% of cases, demonstrating the need for a human-centric security strategy (Kannelønning & Katsikas, 2023). Traditional training programs and one-size-fits-all security policies have failed to adapt to the rapidly evolving threat landscape (Chockalingam et al., 2021). The significance of this study lies in its goal to identify the actions necessary to reduce risk and vulnerabilities by closing the human factor gap in IS and cybersecurity.

Definition of Unclear Terms

- Alert Fatigue: The desensitization that occurs when individuals receive excessive security warnings or repeated training drills. Overexposure can cause employees to dismiss, ignore, or overlook legitimate alerts (Reeves et al., 2021).

- Gamification: The use of game design elements, such as rewards and digital simulations, to create engaging and interactive training that enhances the information and cybersecurity training experience (Chockalingam et al., 2021; Donkeal Chandrashekar et al., 2024).
- Human Factor Gap: The disconnect between an organization's technical safeguards and the actual actions and decisions made by employees in the real world. In the context of information security, it highlights how employee behavior can either strengthen or weaken otherwise robust security controls (Campean, 2019).
- Just-in-Time Training: Training that provides immediate reminders or instructions only when employees are about to perform a sensitive or high-risk task. This timing aims to guide proper decisions and reinforce correct behavior at the point and time of need (Donkeal Chandrashekar et al., 2024).
- Micro-Training: Similar in concept to just-in-time training, micro-training involves delivering training content in brief, targeted bursts at regular intervals or at the moment users make risk-related decisions. This approach can increase knowledge retention while reducing the time burden on employees as compared to a full training cycle (Kävrestad, 2022).
- Shadow IT: When employees utilize inappropriate, uncertified, or unauthorized tools and technologies within the IS (Spivey & McIlveene, 2024).
- Social Engineering: An attack methodology that exploits human interaction and trust to gain unauthorized access or information. Phishing is one example of social engineering, but attackers also use phone calls, in-person manipulation, and various other forms of interaction (Beveridge, 2021).

- Sustained Behavioral Intervention: Security awareness measures delivered on a continuous basis, with frequent updates, feedback, and varied simulations. Long-term engagement aims to reinforce secure habits and discourage complacency (Kävrestad et al., 2022).

Limitations, Delimitations, and Assumptions

The research had some limitations. One limitation was that conclusions can be difficult to generalize because case studies or organizational examples may not be applicable across industries. Further, the quality and availability of sources could bias the study's findings. Another constraint, due to the variable nature of human behavior, was that this research may not be able to draw definitive conclusions about the long-term effectiveness of interventions. Additionally, the rapidly evolving IS and cybersecurity threat landscape makes it challenging to effectively address emerging and evolving threats and technologies. Organizational constraints, such as compliance requirements, resource availability, and resistance to change, are acknowledged but not accounted for in the results or findings of this study. Lastly, this research is intentionally restricted to be specific and informative by focusing on the human aspect of IS and cybersecurity rather than technical measures.

This study assumed that employees are critical to an organization's cybersecurity strategy, influencing organizational resilience through their actions or inactions. It also assumed that this study's selected case studies and empirical evidence are accurate and representative of broad organizational trends.

LITERATURE REVIEW

Cybersecurity breaches appear in news reports with regularity and often indicate that human factors within organizations are the source of the vulnerability (Alotaibi et al., 2019; Ani et al., 2019). While technical controls, such as firewalls, intrusion detection systems, and multifactor authentication, remain critical to an organization's security posture, researchers consistently emphasize that people play a critical role in either reinforcing or undermining security measures (Nasir, 2023; Shah et al., 2023). Employee behaviors often serve as the first line of defense against phishing, malware, or social engineering. However, simultaneously, these same users can be a soft target for threat actors if they do not fully understand and adopt secure behaviors and practices (Donkeal Chandrashekar et al., 2024; Haney & Lutters, 2020).

Recent advances in training methods, such as virtual reality (VR) and augmented reality (AR) simulations, gamification, and micro-training, promise to engage employees more effectively (Alnajim et al., 2023; Carreiro et al., 2024). At the same time, organizational culture, leadership behavior, and sustained behavioral interventions and feedback have surfaced as equally critical for sustaining employees' willingness to follow security protocols (Amankwa et al., 2018; Triplett, 2022). Despite the enthusiasm surrounding these human-centric approaches, challenges remain. Resource constraints, evolving threats, user fatigue, and difficulties in precisely measuring long-term behavior change all impede an organization's ability to maintain an effective security posture (Kannelønning & Katsikas, 2023; Reeves et al., 2021).

This literature review examined existing research on the human factor in IS and cybersecurity, focusing on three core areas that shape organizational security outcomes: (1) the comparative value of targeted, interactive cybersecurity training vs. traditional, generic training; (2) the influence of organizational culture on employees' willingness to comply with security

policies; and (3) the effectiveness of sustained behavioral interventions in reducing employee-related security incidents. Studies from various academic and industry sources highlight both the potential and pitfalls of training programs, underscore the importance of policy alignment with organizational norms, and offer insights into how continuous engagement can close the persistent gap in human-centric defense.

Theoretical Foundations for Security-Related Behavior

Various cognitive, behavioral, and motivational theories provide insight into how employees learn about, absorb, and adhere to information security practices, and are relevant to this thesis's questions. Frequently cited theories are the Theory of Planned Behavior (Ajzen, 1991), the Self-Efficacy Theory (Bandura, 1977), the Protection Motivation Theory (Haag et al., 2021), and the Deterrence Theory (D'Arcy et al., 2009). Each theory aids in explaining different aspects of security awareness, policy compliance, and behavioral change.

Cognitive and Behavioral Theories

Several foundational theories from psychology and organizational studies have been integrated into cybersecurity research to clarify why employees adopt or fail to adopt secure practices. One of the most referenced is Ajzen's (1991) Theory of Planned Behavior, which posits that a person's intention to follow a given behavior arises from three elements: attitudes (whether one believes the behavior is beneficial), subjective norms (whether important others expect this behavior), and perceived behavioral control (whether one feels capable of executing the behavior) and addresses RQ2. As an example, Alotaibi et al. (2019) illustrate how financial department staff may become more willing to follow secure transaction protocols when they sense that peers and supervisors support these practices (subjective norms) and when they believe they have the skills to discern malicious emails (perceived control).

Bandura's (1977) Self-Efficacy Theory highlights how users who feel confident in their ability to identify phishing scams and other common security threats are typically more consistent in upholding secure habits (Alnajim et al., 2023). Both theories emphasize that simple knowledge transfer, such as listing security dos and don'ts, is insufficient. Instead, training must develop a positive outlook on safe behavior, a broader sense of teamwork, responsibility, and a firm assurance in one's capabilities (Kävrestad et al., 2022; Obadofin, 2023). Accordingly, this approach directly addresses RQ1 and RQ3, suggesting that role-specific content and meaningful reinforcement can enhance self-efficacy, prevent complacency, and reduce employee-related security incidents and breaches over time (Donkeal Chandrashekar et al., 2024).

Motivational and Deterrence Perspectives

Complementing these cognitive and behavioral frameworks, motivational theories propose that employees are compelled by both perceived threat severity and their perceived efficacy in managing it (Haag et al., 2021). Under the Protection Motivation Theory, interventions focusing on plausible, high-stakes dangers, such as sophisticated phishing lures or ransomware attacks, prompt employees to take safeguards more seriously (Jansen & van Schaik, 2018). When realistic threat scenarios are paired with clear examples of effective countermeasures, user self-confidence rises, making employees more willing and likely to adopt secure behaviors in actual operational settings (Kävrestad et al., 2022; Taherdoost, 2024b).

However, sustaining this motivation requires balancing awareness with support from management. If managers actively endorse protective behaviors and encourage open reporting of security lapses, employees experience a greater sense of ability, incorporating new lessons into their daily routines (Alotaibi et al., 2019; McKnight & Warkentin, 2020). The concept of "fear-appeals" also applies here: repeated exposure to threat updates can enhance vigilance, but

overuse can lead to fatigue, desensitization, or disengagement (Reeves et al., 2021). For RQ3, refining the frequency and realism of drills can maintain a sense of urgency without overwhelming staff (Chockalingam et al., 2021).

Additionally, organizations that consistently emphasize a collective responsibility for safeguarding information reinforce employees' perceived ability to cope. In a cultural context, when managers support security behaviors and encourage open reporting of suspicious events, individuals feel supported in taking preventive measures rather than fearing punitive consequences if they make a mistake (Alotaibi et al., 2019; McKnight & Warkentin, 2020). As a result, employees are more likely to adopt the secure actions and habits they learned from interactive training sessions as routine tasks, strengthening the overall security culture of the organization. Increasing an employee's threat awareness and providing accessible coping strategies, along with a supportive environment, exemplifies the Protection Motivation Theory. This demonstrates how daily employee conduct can be shifted towards proactively addressing emerging and evolving cyber threats, rather than merely responding to incidents post-occurrence (Reeves et al., 2021). Fear-appeals, frequently employed under this umbrella, are effective but must be managed carefully to avoid complacency or burnout from overuse (Jansen & van Schaik, 2018; Reeves et al., 2021). Reminders of emerging and evolving threats and hands-on practice in recognizing malicious activity help employees maintain awareness (Chockalingam et al., 2021). By continually improving an employee's perceptions of their ability to mitigate different risks, organizations will reinforce threat awareness and coping responses necessary for sustained behavioral change (Taherdoost, 2024b).

Deterrence Theory highlights the role of penalties in shaping user behavior (D'Arcy et al., 2009). Emphasizing disciplinary measures can initially reduce policy violations, yet its long-term

influence may diminish unless it is backed by a culture that genuinely supports and values secure conduct (Willison & Warkentin, 2013). If the organizational culture does not reinforce strict penalties, employees may perceive them as extraneous, resulting in minimal compliance instead of a lasting commitment (Spivey & McIlveene, 2024). This consideration is especially relevant to RQ2, because aligning deterrence measures with the organization's positive security values can encourage adherence beyond simply avoiding punishment.

These frameworks provide foundational insight into each of the research questions outlined in the thesis. Targeted, interactive training (RQ1) benefits employees by increasing their self-efficacy through the utilization of protective motivations and a supportive climate, outperforming generic, penalty-based strategies. An organizationally aligned security policy (RQ2) leverages subjective norms and cultural integration to develop more substantial, natural, and enduring compliance. Finally, sustained behavioral interventions (RQ3) utilize fear-appeals combined with confidence-building strategies to continually reinforce and maintain vigilance, ensuring that each employee's awareness is maintained and secure behavior becomes second nature.

Traditional vs. Interactive Cybersecurity Training

Traditional and Generic Approaches

Characteristics and Prevalence.

Traditional "check-the-box" training is often deployed as a cost-effective and standardized method for disseminating security basics (Haney & Lutters, 2020; Reddy & Dietrich, 2017). These programs often revolve around annually assigned training modules, passive video lectures, or reading materials that employees must confirm they have completed. While they may meet legal and regulatory requirements, they often fall short of developing

substantial behavioral change, especially when perceived as merely procedural tasks (Nasir, 2023).

Advantages and Limitations.

The advantages of generic training include lower developmental and maintenance costs, uniform coverage of essential topics, and alignment with established industry frameworks and compliance standards (Alotaibi et al., 2019). However, employees can grow weary of content that is too broad or remains unchanged from year to year. As a result, they may pass quizzes without actually gaining competence in identifying or preventing threats, simply learning enough to pass the quizzes without internalizing the information or best practices (Reddy & Dietrich, 2017; Taherdoost, 2024a). In some organizations, these training courses can inadvertently promote complacency since employees treat them as a formality rather than a genuine learning opportunity (Haney & Lutters, 2020).

Interactive and Targeted Training

Emergence of Tailored Learning.

In response to the shortcomings of generic training, research proposes methods that are tailored to an employee's specific role or risk profile (Kävrestad, 2022). For instance, departments handling financial transactions or private health data require specialized modules that address the systems and risks relevant to them (Ahmed et al., 2024). Gamified and simulation-based training sessions enable employees to practice threat recognition in realistic environments, often enhancing motivation and knowledge retention (Carreiro et al., 2024; Chockalingam et al., 2021).

Technological Innovations: VR and AR.

Training scenarios using VR and AR solutions provide employees with the opportunity to engage in far more than just watching demonstrations of how to handle simulated security incidents and data breaches. They get to experience the kind of emergency scenarios that might very well occur in real life (Alnajim et al., 2023). The use of VR and AR can strengthen employees' self-efficacy by allowing unlimited attempts at defensive behaviors where the outcomes do not result in harm to the person or organization (Donkeal Chandrashekar et al., 2024). However, despite the favorable findings, widespread adoption remains limited by factors such as the cost of deployment, the need for software updates, and the demand for specialized facilitation (Alnajim et al., 2023).

Contextual and Micro-Training Methods.

In a context-based or micro-training program, an employee is engaged when a security decision must be made. This type of program can remind the employee, via a pop-up prompt or mobile app notification, to verify that a link is safe to click on before they click on it or to use the correct protocol for sharing documents (Kävrestad, 2022; Kävrestad et al., 2022). Research indicates that this just-in-time approach leads to higher knowledge retention rates compared to annual or static sessions (Kävrestad et al., 2022). Short quizzes or dynamic newsletters can also maintain ongoing engagement without overwhelming employees, catering exceptionally well to smaller organizations lacking resources for immersive solutions (Reddy & Dietrich, 2017).

Comparing Training Effectiveness

Behavioral Outcomes and User Engagement.

Despite the variety of training formats, researchers generally agree that interactive, targeted or role-specific methods lead to deeper employee engagement and more sustained

behavioral changes (Carreiro et al., 2024; Taherdoost, 2024b). By actively participating in simulation-based tasks or scenario exercises, employees acquire practical skills that can be applied under actual conditions (Alnajim et al., 2023). Alternatively, while traditional training can raise baseline awareness, particularly for new hires or large-scale organizations, it often does not provide the long-term reinforcement necessary to enable employees to identify and respond to evolving threats effectively (Haney & Lutters, 2020).

Measurements and Assessment.

Evaluating training success goes beyond verifying completion. Researchers employed simulated phishing exercises, post-training quizzes, and user-reported behavior to observe tangible improvements over time (Kannelønning & Katsikas, 2023). Incorporating data from system logs, compliance records, and cultural audits can offer insight into long-term shifts in employee behavior (Alotaibi et al., 2019; Bulgurcu et al., 2010). Additionally, reduced data-handling errors and fewer instances of unauthorized software use also serve as indicators (Carreiro et al., 2024; Ofoegbu et al., 2023).

Counterpoints and Practical Considerations

Limitations of Targeted and Interactive Methods.

Despite their advantages, creating targeted and interactive training modules can be cost prohibitive. Additionally, not all employees prefer or appreciate gamified, VR, or AR-based training formats (Alnajim et al., 2023; Donkeal Chandrashekar et al., 2024). Organizational size, financial resources, and workforce diversity will likely dictate the viability of investing in these high-tech solutions (Reddy & Dietrich, 2017).

Risk of Overemphasizing "Fun".

While gamification techniques can boost participant engagement, they may also result in employees trivializing the seriousness of the threats if the training environment becomes overly playful (Chockalingam et al., 2021). Researchers warn that while fun elements help with knowledge retention, they must be designed to convey the real-world consequences of security incidents and breaches. Balancing interactivity with the severity of security threats is essential for sustaining credibility and prompting correct actions in high-stress situations (Carreiro et al., 2024).

Balancing Traditional and Interactive Approaches.

A practical compromise is a hybrid model, where organizations deliver foundational knowledge through low-cost, traditional modules while supplementing high-risk or specialized roles with more targeted or specifically tailored interactive training (Karjalain & Siponen, 2011; San Nicolas-Rocca & Olfman, 2013). Feedback loops and real-time data on user performance can provide the organization with the information needed to continuously refine training content (Ofoegbu et al., 2023). Regardless of the approach, leadership support and organizational norms remain critical for encouraging employees to treat training seriously (Triplett, 2022).

Organizational Culture and Security Policy Compliance

Conceptualizing Organizational Culture

Organizational culture comprises the unspoken beliefs, values, and norms that shape daily interactions (Hofstede et al., 1990). In IS and cybersecurity, culture influences how employees perceive rules, address risks, and respond to potential threats (Tang et al., 2016). Leaders who publicly support data protection and promote secure behaviors encourage a security-first mindset that gradually becomes part of the workplace routine (Triplett, 2022). Conversely, if leadership

downplays or inconsistently enforces or applies security rules, employees may interpret them as optional (D'Arcy et al., 2009). Culture-related cues often determine whether employees find security policies meaningful or burdensome. When security is perceived as a part of everyday routines, supported by leaders who promote policy adherence, employees will integrate protective habits more seamlessly (Amankwa et al., 2018; Ani et al., 2019).

Aligning Policies with Cultural Values

Relevance to Employee Roles.

Security policies are most effective when they mirror everyday tasks and broader organizational goals (Alotaibi et al., 2019). For instance, if the organizational culture places high value on customer trust, then employees are more likely to accept data protection policies that explicitly show how safeguarding private information strengthens client relationships (Obadofin, 2023). This alignment creates fewer tensions between formal rules and informal norms, reducing the temptation to build workarounds and bypass protocols (San Nicolas-Rocca & Olfman, 2013).

Avoiding Cognitive Dissonance.

When policies require complex or cumbersome procedures, and employees perceive an organizational emphasis on speed or autonomy, they often develop workarounds. In doing so, they circumvent system protections and security protocols in favor of speed and convenience (San Nicolas-Rocca & Olfman, 2013). Conversely, policies that integrate secure behavior and make those actions feel natural will reduce the likelihood that employees develop workarounds (Spivey & McIlveene, 2024). If security guidelines conflict with everyday tasks, frustration and confusion increase, undermining policy adherence. Clear communication, illustrating how secure practices also support efficiency and reliability, eases this cognitive dissonance (Willison & Warkentin, 2013). Additionally, if leadership responds transparently to errors and near-misses,

trust grows, and employees are more likely to identify and escalate concerns when they suspect a security incident or breach (Alotaibi et al., 2019).

The Human Factor in Policy Compliance.

Subjective Norms and Social Pressure.

Ajzen's (1991) Theory of Planned Behavior identifies subjective norms and peer and managerial expectations as a strong driver of compliance. Employees who sense that co-workers are vigilant about security and that supervisors approve of secure practices tend to mimic these norms (Amankwa et al., 2018; Amankwa et al., 2022). In a supportive cultural climate, employees also feel more comfortable asking questions or reporting suspicious anomalies, facilitating timely incident response (Ani et al., 2019). Alternatively, if organizational norms tolerate shortcuts and treat compliance as "optional," employees are likely to neglect the organization's policies and procedures (Anant et al., 2020).

Leadership Modeling and Consistent Enforcement.

Leadership engagement often takes two forms: visible role modeling and consistent enforcement (Georg-Schaffner & Prinz, 2022). When managers openly adhere to security policies, such as using robust passwords or promptly reporting incidents, they reinforce the perception that these measures truly matter, and are not optional (D'Arcy et al., 2009).

Barriers to Effective Culture-Policy Integration

Resistance and Fragmented Communication.

Security policies often require extra steps, such as frequent password updates or multifactor authentication, which can be viewed as obstacles to productivity (Karjalain & Siponen, 2011). If the organizational culture prioritizes speed over thoroughness, employees may secretly circumvent guidelines (Spivey & McIlveene, 2024). Unclear or overly technical policy

documents can further alienate users (Alohali et al., 2018), particularly when leadership offers little, or no, justification for these controls (Winkfield, 2020).

Cross-Cultural Complexities.

Organizations with a multi-national footprint face the additional challenge of dealing with multiple cultural views on authority, autonomy, and risk (Kshetri & Alcantara, 2015). In some cultures, top-down mandates are readily accepted, while in others, collaborative input is fundamental in building trust (Lin et al., 2020; Tang et al., 2016). Designing policy strategies that accommodate these variations in the view of authority can be complex, but it is critical in achieving consistent security outcomes.

Strategies for Promoting Secure Practices

Collaborative Policy Development.

Inviting employees or department representatives to contribute to policy formation promotes relevance and buy-in. Additionally, employees are less likely to perceive the policies as external impositions (Alotaibi et al., 2019). Regular feedback sessions, such as focus groups or departmental surveys, can help identify which rules need adjustment to align with day-to-day workflows and foster a sense of ownership (Taherdoost, 2024a). Leadership support and endorsement of employee-involved policy design demonstrates that the organization values employee input and views security as an organizational priority rather than a box-ticking exercise (Triplett, 2022).

Continuous Training and Reinforcement.

Many researchers propose that culture-policy alignment hinges on consistent reinforcement over time (Haney & Lutters, 2020; Kävrestad, 2022). Short scenario-based workshops, micro-trainings, and refresher modules encourage consistent exposure to emerging

and evolving threats, building awareness, and normalizing compliance practices (Haney & Lutters, 2020; Kävrestad et al., 2022). Publicly recognizing employees or departments that exhibit exemplary security habits can further reinforce positive social norms (Carreiro et al., 2024).

Outcomes of Strong Culture-Policy Alignment

Organizations that align policies with their cultural values tend to experience higher adoption rates and lower instances of policy violations, more transparent reporting channels, and an overall shift toward proactive threat awareness (Bulgurcu et al., 2010; McKnight & Warkentin, 2020; Reddy & Dietrich, 2017). Employees who trust that management treats security as foundational rather than as an afterthought often remain watchful for anomalies, assisting their colleagues in avoiding risky practices (D'Arcy et al., 2009). Further, enhanced trust and proactive reporting also translate into quicker incident detection and containment (Georg-Schaffner & Prinz, 2022). Moreover, this alignment can enhance the organization's public reputation because stakeholders view the organization as a responsible data custodian (Georg-Schaffner & Prinz, 2022). Overall, employees experience fewer conflicts between daily tasks and security requirements, resulting in reduced stress and the reinforcement of a shared sense of responsibility (Amankwa et al., 2018).

Sustained Behavioral Interventions to Reduce Security Incidents

Importance of Continuous Behavioral Change

Short-term training may deliver immediate improvements in user awareness, but genuine habit formation typically requires repeated exposure to learning materials (Willison & Warkentin, 2013). In contrast, sustained interventions, delivered through periodic quizzes, repeated phishing simulations, or micro-lessons, keep security top of mind (Kävrestad et al.,

2022; Reddy & Dietrich, 2017). Drawing on the Theory of Planned Behavior and Self-Efficacy Theory, researchers show that employees need consistent updates, real-time feedback, and repeated practice to fully adopt secure behaviors (Ajzen, 1991; Bandura, 1977). By continually exposing employees to a variety of threats, organizations can minimize their susceptibility to new and fast-changing threats (Anant et al., 2020).

Characteristics of Ongoing Interventions

Periodic Reinforcement and Feedback Loops.

A core feature of sustained interventions involves using constant feedback mechanisms driven by refresher sessions, micro-lessons, or short quizzes (Kävrestad, 2022; San Nicolas-Rocca & Olfman, 2013). For instance, when an employee fails a phishing test, the system automatically notifies them of the warning signals they failed to identify. This quick correction and feedback help the employees associate the lesson with the incident, increasing the recall of the lesson learned (Chockalingam et al., 2021). Aggregating these results at organizational or departmental levels can help leadership identify areas that need more education or clarification of the policies and procedures (Carreiro et al., 2024). Dashboards or game-like metrics that reward performance at the individual and department levels are also beneficial (Ahmed et al., 2024). Informative feedback regarding the most common mistakes and the most ignored phishing signals helps employees improve awareness and correct their practices instantly (Ahmed et al., 2024; Carreiro et al., 2024; Tang et al., 2016)

Role and Department Customization.

Sustained interventions should tailor their content to employees' roles within the organization, focusing on the threats they may specifically encounter (Alnajim et al., 2023). For example, employees in the finance or human resources department handle sensitive data daily.

Handling this data requires specialized instruction on encryption methods to avoid fraudulent activity and to comply with privacy and regulatory requirements (Alnajim et al., 2023). On the other hand, the marketing or information technology staff may only require real-time guidance on safe external communication or software patch management. Tailoring these intervention programs for distinct groups makes them more meaningful and consistently practiced (Donkeal Chandrashekar et al., 2024). When consistently performed and reinforced, this specialization creates a sense of personal importance for the employees. Additionally, leaders who openly promote security best practices and discuss minor incidents constructively create a supportive climate that reinforces the validity of these interventions (Georg-Schaffner & Prinz, 2022; Triplett, 2022).

Leadership and Cultural Support.

A positive organizational climate is essential to the success of a sustained intervention program (Triplett, 2022). Managers and other leadership must clearly communicate expectations, recognize or reward compliant behaviors, and discuss incidents as an opportunity for learning (Lin et al., 2020). Open discussions about minor errors reduce an employee's fear of discipline, and encourage them to report near-misses or vulnerabilities early so they do not escalate unnecessarily (Alotaibi et al., 2019).

Evidence of Improved Security Outcomes

Multiple studies have shown that carefully designed, ongoing interventions reduce phishing click rates, malicious downloads, and the overall frequency of incidents (Kävrestad et al., 2022; Reddy & Dietrich, 2017). By incorporating real-world threat updates, such as new types of ransomwares, organizations help employees develop advanced detection skills that are aligned with and capable of identifying emerging and evolving threats (Willison & Warkentin,

2013). This repetition also effectively encourages alertness as employees learn to anticipate and respond correctly to variations in socially engineered attacks (Taherdoost, 2024b). In many cases, organizations that continually update training content will experience better recognition of emerging threats, reducing security breaches over time (Carreiro et al., 2024).

Counterarguments and Limitations

Alert Fatigue and Diminishing Returns.

Excessive simulations or repetitive fear-appeals can create "alert fatigue," causing employees to dismiss or overlook warnings that may be critical (D'Arcy et al., 2009; Reeves et al., 2021). Over time, excessive reminders can blur the lines between genuine threats and routine exercises. This undermines the severity of actual incidents and results in employees ignoring prompts (Jansen & van Schaik, 2018; Reeves et al., 2021). Moreover, smaller organizations can struggle with the resource demands required for sustaining advanced training cycles (Alnajim et al., 2023). Research advocates for the rotation of training formats, adjusting the frequency of simulations, and ensuring that the content remains relevant to emerging and evolving threats (Carreiro et al., 2024).

Resource Demands.

Implementing ongoing reinforcement models, particularly advanced VR or AR-based programs, require frequent content updates and staff expertise in educational design and threat analysis (Alnajim et al., 2023). Smaller firms may opt for simpler alternatives like short micro-training or automated email prompts. However, even these scaled-down solutions require maintenance and update efforts to stay current with emerging and evolving hacking techniques and other threats (Kävrestad, 2022; Taherdoost, 2024a).

Diverse Cultural and Individual Preferences.

Employees differ in their role and skill level as well as in their cultural or personal backgrounds, all of which influence how they receive and accept continuous feedback (Kshetri & Alcantara, 2015). As such, gamification may, for example, stimulate some employees but alienate others who prefer traditional learning formats (Donkeal Chandrashekar et al., 2024). To be successful, sustained behavior interventions must balance consistency and adaptable content while remaining flexible enough to accommodate diverse learner preferences. This may require combining multiple delivery methods, ranging from gamified simulations to discussion-based or text-based instructions, to be most effective (Lin et al., 2020).

Best Practices for Long-Term Effectiveness

Measurement and Continuous Improvement.

Research emphasizes the consistent monitoring of outcomes, using a variety of metrics, such as click rates on phishing tests, incident logs, and self-reporting surveys (Kannelønning & Katsikas, 2023; Reddy & Dietrich, 2017). This data can guide adjustments to training materials or methods, ensuring they address actual risk areas (Ofoegbu et al., 2023). Refreshing and updating content frequently helps keep pace with new threats, such as evolved phishing lures or unregulated “shadow IT” tools (McManus, 2025; Spivey & McIlveene, 2024).

Integrating Training with Policy Frameworks.

Ongoing interventions are most effective when integrated with overarching security policies and executive endorsement (Lin et al., 2020; Tang et al., 2016). Employees need clear signals from leadership that training is essential, not optional (Triplett, 2022). If users sense that an organization prioritizes security in its daily practices, they are more likely to value continuous training cycles (Alotaibi et al., 2019).

Persistent Challenges and Research Gaps

Resource Constraints

A common concern in the research is the expense and effort required to develop, implement, and maintain interactive or highly tailored security training modules (Alnajim et al., 2023; Chockalingam et al., 2021). For instance, VR, AR, or gamified solutions need specialized software as well as updated hardware, ongoing content creation, and staff training to ensure consistent management (Donkeal Chandrashekar et al., 2024). Many organizations, particularly smaller ones, cite funding and skill limitations as their primary barrier to adopting advanced interactive training or sustained behavioral programs (Alnajim et al., 2023; Reddy & Dietrich, 2017).

Several studies propose phased or modular approaches to address this issue. One suggested solution is micro-trainings that use existing intranet infrastructures (Carreiro et al., 2024; Kävrestad, 2022). However, there is a gap in the literature around the cost-effectiveness comparisons across various interactive programs; few studies comprehensively analyze the return on investment over time (Nasir, 2023). As a result, organizational decision-makers lack detailed guidelines to help them evaluate whether advanced initiatives like immersive simulations will produce substantial, long-term security gains in proportion to their implementation and operational costs.

Evolving Threat Landscape

Another major obstacle cited in the research is the rapidly changing nature of cyber threats, including sophisticated phishing schemes, social engineering tactics, and the growing use of AI-based malicious tools (McManus, 2025; Shah et al., 2023). Organizations that conduct one-time or infrequent training risk leaving their employees unaware of new or changing attack

methods (Willison & Warkentin, 2013). Jansen and van Schaik (2018) found that employees who are limited to receiving only annual refresher training are often unable to respond effectively to new threats because annual training does not provide information about threats that have emerged or evolved throughout the year.

Although researchers like Spivey and McIlveene (2024) advocate for frequent scenario-based exercises and updated phishing simulations to keep pace with these constant changes, implementing regular updates can be logistically difficult (Reddy & Dietrich, 2017). Organizations may not have a dedicated team, or the expertise required to track the latest threats, quickly convert these findings into training materials, and deploy them to employees (Haney & Lutters, 2020). Consequently, a gap forms regarding the best way to operationalize ongoing threat tracking and the incorporation of that intelligence into the training processes while avoiding potential alert fatigue (Reeves et al., 2021).

Alert Fatigue and Diminishing Returns

Alert fatigue happens when employees are presented with excessive warnings, pop-up notifications, or simulated threats, causing genuine alerts or threats to lose their impact and to possibly be ignored (Jansen & van Schaik, 2018; Reeves et al., 2021). Repeatedly exposing employees to the same phishing drills, compliance prompts, or fear-based messages can inadvertently desensitize them, causing the real and critical notices to be ignored (D'Arcy et al., 2009; Haney & Lutters, 2020). Employees who initially responded well to interactive training modules or real-time threat intelligence updates may become fatigued if these interventions do not adapt to changing threat patterns or workplace routines (Carreiro et al., 2024; Taherdoost, 2024a). Although some repetition can help to reinforce secure habits, researchers caution that monotonous or overly frequent alerts and notifications can result in complacency rather than

supporting alertness (Reeves et al., 2021). To address this, organizations must carefully balance their approach, alternating simulation formats, refreshing messaging content, and integrating more substantial, scenario-based learning to keep their security awareness efforts engaging without causing employees to tune out (Spivey & McIlveene, 2024).

The concept of "diminishing returns" addresses how repeated exposure to the same cybersecurity training or interventions results in a steady decline in effectiveness despite the continued investment of time and resources (Almansoori et al., 2023; Taherdoost, 2024a). When training or intervention programs are first implemented, organizations may experience measurable improvements in user awareness and reduced security incidents (Chockalingam et al., 2021). However, these gains will likely plateau and then decrease as employees become accustomed to familiar protocols, quizzes, or simulated scenarios and begin viewing them as routine tasks rather than opportunities to test their skills (Reeves et al., 2021). Once this begins, additional training evolutions may also fail to yield increased comprehension, motivation, or the development of secure practices (Taherdoost, 2024a). While rotating content, integrating real-time updates, and tailoring modules to different employee roles can delay this decline (Almansoori et al., 2023), many organizations still struggle to balance necessary reinforcement and over-saturation. As a result, further empirical research is needed to identify how frequently training modules should be updated or altered to sustain engagement and avoid entering a state of diminishing returns (Kävrestad et al., 2022).

Cultural Barriers and Workarounds

Research also highlights the substantial impact of organizational culture on employees' acceptance or rejection of security policies (Tang et al., 2016; Triplett, 2022). Alotaibi et al. (2019) suggest that employees who view security measures as irrelevant or cumbersome tend to

engage in workarounds to complete their tasks more efficiently, undermining compliance and exposing systems to unanticipated vulnerabilities. Spivey and McIlveene (2024) confirm that many employees bypass processes, especially in cultures that reward speed over cautiousness, consequently widening the human factor gap.

Additionally, Georg-Schaffner and Prinz (2022) show that even advanced training solutions are not fully effective if management does not model secure behaviors, support policy enforcement consistently, or communicate why particular safeguards matter. However, specific processes or frameworks to help organizations integrate secure practices into their existing norms remain scarce in the literature (Lin et al., 2020). While some research advocates for participatory policy development to drive cultural alignment (Alotaibi et al., 2019), most case studies do not specifically deal with how to put ongoing, organization-wide participation into practice. Therefore, a gap exists in providing systematic approaches to align everyday work culture with security policies, specifically when dealing with multinational environments that are comprised of diverse cultural norms (Kshetri & Alcantara, 2015).

Measuring Long-Term Impact

Accurate measurement of behavior change remains challenging, as many studies rely on immediate quizzes or short-term incident statistics (Haney & Lutters, 2020). Overreliance on a single metric, such as phishing clicks, can mask deeper issues, like repeated near-misses or unreported policy violations (Kannelønning & Katsikas, 2023). Researchers increasingly call for multi-faceted evaluations that combine user surveys, direct observations, system logs, and interviews to capture subtle shifts in attitudes, norms, and real-world practices (Kävrestad et al., 2022).

Sustained Engagement and Attention

Security training programs risk diminishing returns if employees feel that the material is repetitive or irrelevant (Almansoori et al., 2023; Taherdoost, 2024a). Alert fatigue, primarily in organizations that frequently conduct simulations or send repeated cautionary messages, can reduce alertness (Reeves et al., 2021). To counter boredom and complacency, researchers suggest rotating different teaching formats, such as videos, discussion groups, micro-trainings, and regularly updating examples that reflect recent data breaches or security incidents (Chockalingam et al., 2021; Donkeal Chandrashekar et al., 2024).

Measuring Long-Term Behavior Change

Another challenge concerns how researchers and organizations measure long-term shifts in user behavior after training or new policy implementation. Haney and Lutters (2020) found that many training programs put too much emphasis on post-training quizzes that are administered immediately after the training has been completed. These types of quizzes may measure short-term knowledge gain, but are unlikely to indicate if employees maintain secure behaviors under stressful or unforeseen circumstances. Kannelønning and Katsikas (2023) emphasize that frequent data captures, such as the results from routine phishing simulations, system log monitoring, and anonymous employee surveys, may provide a better picture of sustained compliance and may detect more subtle forms of non-compliance or near-misses that do not get reported.

Despite these recommendations, few empirical investigations have tracked employees over extended timeframes to identify what methods or frequencies of interventions yield the longest-lasting improvements (Kävrestad et al., 2022). As such, it is impossible to know whether results from single-point measurements genuinely represent the strength and depth of an

organization's security culture (Bulgurcu et al., 2010). As a result, and without a standardized, multifaceted approach, organizations risk overestimating their readiness or missing latent vulnerabilities.

Sustaining Employee Engagement

The research recognizes that sustaining employee engagement and motivation is a primary challenge (Amankwa et al., 2022; Haney & Lutters, 2020). Especially in environments where security awareness training remains repetitive or does not evolve as an employee's job also evolves (Almansoori et al., 2023). Employees exposed to the same phishing simulations, static policy directives, or repeated fear-appeals may become complacent over time, reducing the impact of the training and interventions (Chockalingam et al., 2021). Reeves et al. (2021) further observe that alert fatigue can occur when people are repeatedly alerted to hypothetical threats but rarely witness material consequences, resulting in them ignoring or dismissing official warnings.

Some studies recommend altering the training method and frequency, mixing micro-trainings, gamified simulations, interactive workshops, and scenario-based case studies in order to maintain curiosity and awareness (Donkeal Chandrashekar et al., 2024; Jansen & van Schaik, 2018). Beyond suggesting diversity in training formats, the literature makes fewer concrete suggestions for systematically customizing materials to diverse groups or industries without causing information overload (Ani et al., 2019). This implies another research gap: identifying scalable frameworks that make security awareness fresh and applicable while meeting individual learning styles and organizational limitations (Karjalain & Siponen, 2011).

Conclusion of the Literature Review

Across the literature, scholars and organizations frequently cite the significance of the human factor in IS and cybersecurity as a priority. Organizations cannot rely on technical

controls alone, given that employees often represent both the first line of defense and a point of significant vulnerability (Nasir, 2023; Shah et al., 2023). While preventive measures such as firewalls, intrusion detection, and advanced encryption provide essential barriers, real-world incidents frequently hinge on users' awareness, motivation, and cultural context (Donkeal Chandrashekar et al., 2024; Haney & Lutters, 2020).

The research strongly suggests that traditional training, though economical and often sufficient for compliance requirements, may not produce the depth of engagement or long-term behavioral commitment needed to mitigate ever-evolving threats (Reddy & Dietrich, 2017; Taherdoost, 2024a). In contrast, interactive, tailored methods consistently show promise in reinforcing positive security habits, elevating a user's self-efficacy, and reducing overall incident rates (Alnajim et al., 2023; Kävrestad et al., 2022). However, immersive technologies' operational and financial demands, gamified modules, or specialized micro-trainings can overwhelm smaller or resource-constrained organizations (Carreiro et al., 2024; Donkeal Chandrashekar et al., 2024). This tension points to a need for hybrid strategies and incremental rollouts that maintain engagement without overspending budgets or overwhelming employees (Haney & Lutters, 2020).

Beyond training, existing research stresses the fundamental role of organizational culture in determining whether employees embrace or circumvent security measures (Lin et al., 2020; Triplett, 2022). Cultural alignment and supportive leadership have been linked to fewer policy violations, increased transparency, and more collaborative attitudes toward risk management (Alotaibi et al., 2019; Georg-Schaffner & Prinz, 2022). Likewise, sustained behavioral interventions, particularly those that adapt to emerging threats and offer real-time feedback, help maintain a higher level of alertness while minimizing issues such as alert fatigue or diminishing

returns (Almansoori et al., 2023; Reeves et al., 2021). However, the hurdles of resource constraints, the rapid evolution of threats, and the universal challenge of measuring authentic, long-term behavior change continue (Kannelønning & Katsikas, 2023; Kävrestad et al., 2022).

This literature review highlights significant advancements in designing human-centric IS and cybersecurity solutions while exposing key gaps in practice. Although targeted training, policies that align with organizational norms, and ongoing behavioral interventions have demonstrated an apparent capacity to reduce user-related vulnerabilities, questions remain about how to integrate these measures so that they effectively scale across diverse industries and cultures (Kshetri & Alcantara, 2015; Spivey & McIlveene, 2024). More specifically, researchers and organizations still require clearer metrics for gauging whether interactive methods produce a proportional return on investment, how to tailor policy frameworks in multinational organizations, and which benchmark measures best capture gradual yet meaningful shifts in user behavior over extended periods.

According to the literature, the field could benefit from systematic cross-comparisons of different interactive learning strategies, from gamified phishing simulations to micro-training protocols, in order to identify and refine the most impactful approaches (Nasir, 2023; Shah et al., 2023). Further, it suggests that greater attention to cross-cultural distinctions may offer a path to more precise policy alignments that resonate with local norms and values (Kshetri & Alcantara, 2015). In doing this, organizations would not only reinforce technical defenses but also engage their employees as active partners in cybersecurity. Connecting these insights to operational requirements significantly improves the possibility of creating sustainable, resilient, and human-centric IS and cybersecurity defense systems, even in a worsening threat environment (Amankwa et al., 2018).

METHODOLOGY

Subjects and Setting

As a qualitative study utilizing secondary data, no direct participants were sampled. The research analyzes peer-reviewed articles, industry documents, incident statistics, and case studies from various industries and organizational structures to provide multiple viewpoints. The research case selection criteria involved three elements: presence in the industry, IS and cybersecurity policy implementation, and strategies used in training. This selection method allowed for a comparative analysis between strategies that work and those that do not.

Data Collection Technique

This study relied on secondary qualitative academic literature, case studies, and existing quantitative research to examine the role of cybersecurity training, behavioral interventions, and culturally aligned policies and their effect on employee security behaviors. Real-world applicability was assessed using multiple case studies to statistically compare compliance rates and training effectiveness. Multiple data types and sources were used in this study to ensure a thorough and balanced assessment of human-centric IS and cybersecurity strategies.

A structured search method was used to collect relevant data and insights. This study combined key terms like: “cybersecurity training,” “behavioral interventions,” “culturally aligned policies,” “human-centric information security,” “employee security compliance,” and “cybersecurity awareness” with IS and cybersecurity-related keywords across multiple academic databases such as American Public University System Trefry Library, ScienceDirect and Google Scholar. Combining synonyms and other closely related terms provided broad coverage of academic literature, relevant case studies, and quantitative research related to the study's goals.

Statistical Analysis

This research utilized quantitative data and findings from existing academic studies, industry reports with relevant trends and metrics, and other empirical sources. By analyzing these materials, the study compares how well different security training methods work, evaluates policy adherence, and assesses the impact of various behavioral interventions. Industry data provides statistical trends, like changes in phishing susceptibility and policy violations, providing a basis for measuring the effectiveness of training programs. Additionally, compliance data was examined before and after new policies took effect to identify changes in policy compliance. Case studies were reviewed to provide context for the research study's results, aiding in identifying patterns in policy implementation, employee participation, and organizational security culture development.

Hypotheses

This research study employed a series of null and alternative hypotheses to evaluate the impact of training, culturally aligned policies, and behavioral interventions on employee security practices. The goal was to determine their effectiveness in addressing the human factor gap in IS and cybersecurity. The null hypotheses indicate that there is no significant impact, while the alternative hypotheses suggest that the effects have a measurable or significant impact. The research hypotheses established a foundation of empirical evidence to test whether closing the human factor gap decreases organizational weaknesses.

- Targeted Cybersecurity Training vs. Traditional, Generic Training
    - Null Hypothesis (H_0): Employees who receive interactive, targeted cybersecurity education exhibit no significantly different security behaviors than those who receive traditional, generic training.

  - Alternative Hypothesis (H_1): Employees who receive interactive, targeted cybersecurity education exhibit significantly different security behavior outcomes than those who receive traditional, generic training.
- Influence of Organizational Culture on Security Policy Compliance
  - Null Hypothesis (H_0): Security policies aligned with organizational culture do not significantly influence employees' compliance with security policies.
  - Alternative Hypothesis (H_1): Security policies aligned with organizational culture do significantly influence employees' compliance with security policies.
- Impact of Sustained Behavioral Interventions on Employee Security Incidents
  - Null Hypothesis (H_0): Sustained behavioral interventions have no significant effect in reducing employee-related security incidents.
  - Alternative Hypothesis (H_1): Sustained behavioral interventions have a significant effect in reducing employee-related security incidents.

Limitations of the Study

This research study relied on secondary data, limiting its findings to existing information. As a result, this study may not be able to fully address emerging or evolving IS or cybersecurity threats, or changes in employee behavior. The accuracy and completeness of this research study are directly tied to the quality and comprehensiveness of those secondary data sources. Biases or gaps in the selected sources could lead to biases or gaps in this research study. Additionally, the generalizability of its findings may be influenced by the metrics used for statistical comparisons in this study. Because this research study lacks primary data collection, its findings' real-time relevance and applicability may be affected. Lastly, the knowledge and conclusions found in this study are based on documented case studies rather than direct observation or experimentation.

RESULTS

This section presents the results of a comprehensive study of secondary data sources related to human-centric IS and cybersecurity strategies, focusing on their role in addressing human-factor-related vulnerabilities. It examines how interactive training programs, policies aligned with organizational culture, and continuous behavioral interventions can collectively reduce the human factor gap. Aligning with the literature review, these results address each research question, emphasizing the significance of incorporating technical IS and cybersecurity safeguards with the employees responsible for operating these systems.

Overview of Data Sources and Methodological Context

Nature of the Data Examined

The data used for this study included peer-reviewed articles, conference proceedings, dissertations, and industry white papers regarding employee errors, oversight, and policy workarounds. The selected sources discuss:

- Phishing Simulations

  Researchers measured click rates and the accuracy of identifying malicious emails. This method is widely used to gauge an employee's susceptibility to social engineering (Ahmed et al., 2024; Beveridge, 2021; Kävrestad et al., 2022).

- Policy Violation Logs

  Studies tracked incidents like unauthorized software use or non-adherence to encryption mandates, providing quantitative insight into employee security violations (Amankwa et al., 2018; Carreiro et al., 2024).

- Qualitative Assessments

  Surveys and interviews with employees, managers, and industry experts uncovered

subjective norms, attitudes, and perceptions of organizational policies (Chockalingam et al., 2021; Georg-Schaffner & Prinz, 2022; Morgan, 2023; Reeves et al., 2021).

Using multiple data points allowed for a more holistic examination of how the human factor gap, defined here as the divergence between established technical protections and the reality of employee actions, manifests in various operational contexts such as healthcare, financial services, manufacturing, and public agencies (Alotaibi et al., 2019; Nasir, 2023).

Data Collection Emphasis

Researchers frequently used mixed methods. While most contributed quantitative indicators of employee behavior, such as phishing click rates and frequency of security policy non-compliance, some supplemented these metrics with qualitative insights into organizational culture, leadership engagement, and perceptions of threat severity (Ani et al., 2019; Morgan, 2023; Reeves et al., 2021). Combining both numerical and narrative data facilitated robust cross-validation of how well interactive training, policy alignment, and reinforced interventions close the human factor gap (Amankwa et al., 2022; He et al., 2020; Raineri & Resig, 2020; Taherdoost, 2024a).

Theoretical Perspectives and Observed Behaviors

There are multiple theories referenced across studies when discussing employee-related security behavior:

Theory of Planned Behavior (TPB)

TPB argues that attitudes toward security, subjective norms within the workplace, and employees' perceived behavioral control jointly influence the likelihood of secure conduct (Ajzen, 1991). In contexts where managers and peers encourage security and employees feel

confident in their capabilities, the human-factor gap narrows (Alotaibi et al., 2019; McKnight & Warkentin, 2020).

Self-Efficacy Theory

Self-efficacy theory suggests that confidence in recognizing and responding to threats grows through sustained learning cycles and positive reinforcement (Bandura, 1977). Simulation-based training builds employee self-efficacy, enabling them to face genuine security challenges with greater competence and confidence (Donkeal Chandrashekar et al., 2024; Raineri & Resig, 2020).

Protection Motivation Theory (PMT)

PMT proposes that employees' motivation to adopt secure behaviors comes from perceived threat severity and the belief that they can effectively cope (Haag et al., 2021). Role-specific drills and fear-appeals must be balanced with practical steps employees can take, ensuring the perceived severity of the threat does not overwhelm employees but prompts them to act (Jansen & van Schaik, 2018; He et al., 2020).

Deterrence Theory

Deterrence theory emphasizes the significance of punishment or penalties in reducing policy non-compliance (D'Arcy et al., 2009). While the threat of penalties can improve short-term compliance, cultural integration and consistent enforcement are necessary for genuine, long-term behavior shifts (Spivey & McIlveene, 2024; Willison & Warkentin, 2013).

Observed employee behaviors align with these theories when, for instance, interactive training (Self-Efficacy; PMT) is strengthened by a supportive cultural climate (TPB) and a fair, consistent enforcement policy (Deterrence Theory). Table 1 summarizes how the theories relate to specific behaviors that help close the human factor gap.

Table 1

Theoretical Foundations and Related Secure Behaviors

Theory	Key Components	Secure Behavior Manifestations	Representative Sources
Theory of Planned Behavior	Attitudes, Subjective Norms, Perceived Behavioral Control	Employees abide by policy when they see positive peer norms and feel capable of fulfilling the requirement.	(Ajzen, 1991); (Alotaibi et al., 2019); (McKnight & Warkentin, 2020)
Self-Efficacy Theory	Belief in one's capability to execute tasks successfully	Training with hands-on drills promotes confidence in detecting advanced phishing attempts.	(Bandura, 1977); (Donkeal Chandrashekar et al., 2024); (Kävrestad et al., 2022)
Protection Motivation Theory	Perceived threat severity + coping appraisal	Employees adopt secure protocols when they perceive threats as credible and know how to respond effectively.	(Haag et al., 2021); (Jansen & van Schaik, 2018); (Taherdoost, 2024b)
Deterrence Theory	Punishment as a preventive measure	Clear punitive measures deter policy violations if the organization consistently enforces them.	(D'Arcy et al., 2009); (Spivey & McIlveene, 2024); (Willison & Warkentin, 2013)

Overview of Data Organization

The following sections address each research question, detailing how targeted training, culturally aligned policies, and sustained behavioral interventions help to close the human factor gap. Tables 2 and 3 synthesize quantitative and qualitative findings, while Table 7 provides additional empirical data from multiple dissertations and peer-reviewed articles.

RQ1: Comparing Interactive, Targeted Training with Traditional, Generic Training

Distinctions Between Traditional and Interactive Methods

Traditional "Check-the-Box" Training.

Many organizations maintain annual or semi-annual generic training modules as their primary method of employee security education (Haney & Lutters, 2020; Reddy & Dietrich, 2017). While this method covers fundamental concepts, such as strong passwords and phishing recognition, these sessions often fail to bridge the gap between user knowledge and daily operational pressures (Reeves et al., 2021). Studies also highlight the tendency for employees to view such content as an obligatory chore, leading to superficial engagement (Nasir, 2023; Taherdoost, 2024a).

Interactive and Targeted Approaches.

A substantial body of literature points to simulation-driven, gamified, and context-based micro-trainings as more effective than one-size-fits-all instruction (Carreiro et al., 2024; Chockalingam et al., 2021; Donkeal Chandrashekar et al., 2024). Healthcare professionals reported significantly higher vigilance in spotting malicious attachments after engaging in interactive modules (Carreiro et al., 2024). Likewise, a public agency deploying micro-trainings saw notable reductions in persistent phishing errors and improved security-related feedback loops (Kävrestad et al., 2022). Additional evidence from Beveridge (2021) indicates that realism in scenario-based training, such as closely mimicking real-world phishing cues, can reduce phishing click rates by more than half, from 18.1% to 8.7%, in just six weeks.

Evidence of Improved Awareness and Behavior

Phishing Susceptibility Metrics.

Ahmed et al. (2024) documented that at a financial institution, employees exposed to gamified phishing simulations decreased click rates by over 15% compared to employees who completed standard video-based courses. Meanwhile, Workman (2021) found that a blended training approach, instructor-led + e-learning, yielded a 16% improvement in detecting phishing emails, nearly double the 8.5% gain among those using e-learning alone.

Consistency in Secure Practices.

Reddy and Dietrich (2017) found that hybrid training, such as generic modules supplemented with monthly scenario-based exercises, corresponded with a tangible reduction in unauthorized software installation, helping close the gap between policy and day-to-day reality. He et al. (2020) similarly showed that an evidence-based malware training curriculum lifted post-training threat-recognition scores to 80.3%, up from 62.5% pre-training.

Self-Efficacy and Operational Efficiency.

Research shows that when employees gain confidence in detecting or blocking threats, they are less likely to interrupt workflows to verify every message with IT, enhancing operational efficiency (Chockalingam et al., 2021; Donkeal Chandrashekar et al., 2024). Raineri and Resig (2020) noted a 0.87-point jump (on a five-point scale) in cybersecurity self-efficacy among small-business owners after brief workshops, indicating these gains occur even in resource-limited environments.

Table 2

Comparison of Targeted Interactive and Traditional Generic Training Methods

Aspect	Interactive, Targeted Training	Traditional, Generic Training
Conceptual Foundations	Heavily influenced by behavior change theories such as the TPB (Ajzen, 1991) and Self-Efficacy Theory (Bandura, 1977). Customized content addresses specific attitudes, perceived behavioral control, and social norms (Almansoori et al., 2023).	Often designed primarily for compliance purposes; less apt to integrate core behavioral frameworks like TPB or self-efficacy. Programs typically focus on standardized content without tailoring to individuals' psychological drivers (Alotaibi et al., 2019).
Level of Engagement	Research shows that interactive approaches, such as gamified content, role-play, and scenario-based simulations, keep users more engaged, enhance self-efficacy, and develop positive attitudes toward secure behavior (Alnajim et al., 2023; Carreiro et al., 2024).	Generic, one-size-fits-all modules or lectures often yield lower engagement. Employees perceive them as repetitive or irrelevant, leading to minimal motivation to internalize secure practices (Almansoori et al., 2023; Haney & Lutters, 2020).
Relevance & Contextualization	Targeted training addresses role-specific risks and scenarios, like HR vs. IT staff. This aligns training content with actual tasks, creating stronger behavioral intentions to comply with security policy (Amankwa et al., 2018).	Generic programs lack contextual specificity. Generic videos or slides often do not address nuanced real-world threats faced by different roles or departments, decreasing perceived usefulness (Alohali et al., 2018).
Behavioral Change & Policy Compliance	Tailored interventions focusing on attitudes, norms, and perceived control are more likely to shape secure behavior. These methods have been linked to better policy compliance cultures (Amankwa et al., 2022) and stronger organizational commitment (Bulgurcu et al., 2010).	Training is often transactional and oriented toward fulfilling a compliance checkbox. It may raise some awareness but is less effective at altering daily habits or ingrained security behaviors (Alotaibi et al., 2019). Over time, employees revert to old habits if not continually engaged (Ani et al., 2019).

Use of Technology & Innovation	Training can include online simulations, VR/AR experiences, quizzes, or microlearning. Such interactive media aligns with active learning principles, increasing cognitive processing and motivation (Alnajim et al., 2023).	Typically uses pre-recorded videos or slide decks. Less interactive technologies reduce learner's engagement and real-time feedback. Modern immersive or gamified elements are rarely implemented in older, generic programs (Alohali et al., 2018).
Outcomes on Risk-Taking Behavior	Personalized training can reduce risky digital behavior by reinforcing positive self-efficacy and emphasizing immediate consequences of risky actions (Alohali et al., 2018). More frequent practice and feedback loops result in greater security awareness (Almansoori et al., 2023).	Generic training may highlight risks but fails to change the foundations of risk-taking behaviors (Alohali et al., 2018). Without tailored strategies to address user motivations and psychological barriers, the impact on actual behavior is limited.
Organizational Culture Integration	By considering organizational culture and subcultures, interactive training can be aligned with management support and positive security norms, strengthening a security compliance culture (Amankwa et al., 2018; Campean, 2019).	Generic approaches often treat the organization as monolithic. Failing to align with culture can result in employees not embedding security norms into daily practice (Amankwa et al., 2018).

Ties to Theoretical Perspectives

- Self-Efficacy Theory: Repeated, hands-on exposure substantially boosts employees' belief in their capacity to thwart malicious actions, bridging the human factor gap (Bandura, 1977; Kävrestad et al., 2022; Raineri & Resig, 2020).
- Protection Motivation Theory: Realistic role-play scenarios heighten perceived threat severity and encourage employees to adopt protective habits and behaviors (He et al., 2020; Jansen & van Schaik, 2018).

Summary for RQ1

Evidence consistently demonstrates that interactive, role-specific training is more effective at developing sustained, secure behaviors than conventional, generic methods (Ahmed et al., 2024; Beveridge, 2021; Carreiro et al., 2024). While advanced training methods like VR or AR require resources, their targeted benefits, improved threat identification, and lasting skill acquisition help reduce employee-initiated breaches, effectively narrowing the human factor gap (Haney & Lutters, 2020; Workman, 2021).

RQ2: How Organizational Culture and Norms Influence Policy Compliance

Importance of Culture in Shaping Security Conduct

Researchers repeatedly emphasized the necessity of cultural alignment to facilitate translating security mandates into everyday practices (Alotaibi et al., 2019; Amankwa et al., 2022). If organizational leadership consistently models data protection, employees often perceive secure practices as integral to daily routines (Georg-Schaffner & Prinz, 2022). Where culture favors speed or sees security as optional, employees are more likely to engage in risky workarounds (Spivey & McIlveene, 2024). Morgan (2023) notes that many end-users underutilize existing security features, such as two-factor authentication and reporting capabilities. This suggests that organizational culture and, by extension, leadership priorities must reinforce consistent user education to prevent complacency.

Table 3

Comparison of Aligned and Misaligned IS and Cybersecurity Policies

Aspect	Policies Aligned with Corporate Culture & Norms	Policies Not Aligned with Corporate Culture & Norms
Attitudes & Behavioral Intent	Grounded in Theory of Planned Behavior (Ajzen, 1991), aligned policies leverage positive attitudes and social norms. Clear alignment promotes employees' intent to follow security guidelines. For instance, cohesive policies help reinforce user beliefs that compliance is both beneficial and expected (Bulgurcu et al., 2010; Amankwa et al., 2022).	Misaligned policies create skepticism and resistance. Employees may view policies as externally imposed rules that clash with day-to-day practices, eroding behavioral intent to comply. Without clear cultural fit, workers may lack the intrinsic motivation to follow guidelines (Lin et al., 2020).
Organizational Culture & Fit	Building on Hofstede et al. (1990) and Tang et al. (2016), well-aligned policies acknowledge shared values and norms, embedding security as part of organizational identity. Leaders model compliance, promoting a positive security culture (Amankwa et al., 2018).	Policies that ignore or contradict key cultural dimensions (e.g., power distance, individualism-collectivism) can be perceived as irrelevant or too rigid. Such misalignment undermines employees' sense of ownership, increasing the likelihood of subversion or policy noncompliance (Tang et al., 2016; Willison & Warkentin, 2013).
Normative & Peer Influences	Aligned policies harness peer pressure positively, so individuals are more inclined to follow "what everyone else does." By embedding security practices into cultural routines, employees internalize norms that dissuade policy violations (Ajzen, 1991; Bulgurcu et al., 2010).	If policies conflict with existing workplace norms, such as "shortcut culture," and unwritten rules to prioritize speed over procedure, peers may encourage noncompliance. Employees may fear social backlash for following inflexible policies, increasing the risk of security violations (Ani et al., 2019).

Self-Efficacy & Ownership	Drawing on Bandura (1977), employees who feel confident and know how and why to comply are more engaged. Aligned policies typically include contextually relevant guidance and training, boosting self-efficacy and personal ownership of security behaviors (Alohali et al., 2018; Amankwa et al., 2022).	Misalignment reduces the clarity and practicality of policies, lowering user self-efficacy. Confusion or perceived irrelevance leads employees to skip compliance steps or default to risky behaviors. Over time, they become disengaged from official security mandates (Ani et al., 2019; Willison & Warkentin, 2013).
Policy Compliance & Violation Rates	Empirical findings show that organizationally congruent security policies, such as addressing role-specific needs and matching corporate values, correlate with higher levels of compliance and lower violation rates (Alotaibi et al., 2019; Bulgurcu et al., 2010). Employees view such policies as legitimate, fair, and beneficial.	Where security mandates feel forced or do not align with local norms, violation rates tend to be higher (Alotaibi et al., 2019). Employees find workarounds or disregard guidelines altogether, undermining the effectiveness of security measures. This misalignment can foster a compliance culture gap (Amankwa et al., 2018).
Sustained Organizational Impact	Over time, aligned policies reinforce a broader security compliance culture: employees become proactive in security reporting, risk awareness, and supporting each other's compliance efforts (Amankwa et al., 2022). The result is an embedded practice that is less susceptible to lapses or malicious insider threats.	Persistent misalignment can create cynicism, where employees see security measures as a "necessary evil" rather than a shared responsibility. This undermines long-term compliance, leaving organizations more vulnerable to insider threats and repeated policy breaches (Lin et al., 2020; Willison & Warkentin, 2013).

Documented Reductions in Policy Violations

Fewer Workarounds.

San Nicolas-Rocca and Olfman (2013) demonstrated that once employees recognized policy elements as integral to customer trust or patient safety, they abandoned shortcuts.

Lower Insider Breach Incidents.

In manufacturing settings, embedding security practices into existing quality control norms reduced unauthorized USB use and password-sharing by nearly 30% (Amankwa et al., 2018).

Improved Reporting and Transparency.

Organizations that encouraged open discussions about near-misses or suspicious behaviors reported faster incident escalation and fewer unrecognized breaches (Lin et al., 2020; Obadofin, 2023).

Influence of Subjective Norms and Peer Pressure

In line with Ajzen's (1991) Theory of Planned Behavior, employees mimic the behaviors and expectations they observe from influential peers (Alotaibi et al., 2019; Amankwa et al., 2022). Departments that publicly rewarded secure behaviors tended to see a quicker shift in social norms, pressuring previously complacent staff to conform (Ani et al., 2019).

Summary for RQ2

Policy adherence improves when leadership and broader cultural values reinforce security as a core component of organizational identity, connecting compliance to a higher institutional purpose (Alotaibi et al., 2019). The data underlines how consistent managerial modeling, recognition, and alignment with mission-driven priorities help close the human factor gap by

making employees co-owners of security (Georg-Schaffner & Prinz, 2022; Morgan, 2023; Willison & Warkentin, 2013).

RQ3: Effectiveness of Sustained Behavioral Interventions in Reducing Incidents

Significance of Continuous Reinforcement

Single or one-off training sessions only produce temporary gains in vigilance (Reeves et al., 2021; Willison & Warkentin, 2013). Recurring simulations, micro-trainings, and real-time feedback reminders yield more consistent engagement. Kävrestad et al. (2022) documented a sustained 15% decrease in phishing susceptibility following periodic tests that reinforced previously learned cues.

Table 4

Comparison of Sustained and Short-term or No Interventions

Aspect	Sustained Behavioral Interventions	Short-Term or No Interventions
Theoretical Foundations	Often grounded in Ajzen's (1991) Theory of Planned Behavior and Bandura's (1977) Self-Efficacy framework, emphasizing continuous reinforcement to support changes in attitudes, norms, and personal efficacy (Amankwa et al., 2022).	Short-term sessions or one-off directives may lack a robust theoretical basis, emphasizing compliance checklists rather than systematic, ongoing behavior change (Alotaibi et al., 2019; Bulgurcu et al., 2010).
Frequency & Reinforcement	Delivered periodically, such as monthly or quarterly, providing consistent refreshers and new scenarios (Ani et al., 2019). This ensures that employees receive ongoing feedback, gradually internalizing secure habits.	A single workshop or annual training with no follow-up. Knowledge and motivation decay rapidly over time; employees often revert to older habits if not continuously reinforced (Ani et al., 2019; Willison & Warkentin, 2013).

Impact on Self-Efficacy & Skill	By reinforcing skills over time, employees gain confidence in their ability to detect and respond to security threats. High self-efficacy decreases fear and increases proactive security behaviors (Alohali et al., 2018; Bandura, 1977).	Without ongoing practice or reinforcement, employees may not develop lasting confidence in applying security best practices. Uncertainty persists, increasing risky or avoidant behaviors (Willison & Warkentin, 2013).
Cultural & Normative Effects	Sustained interventions align with a broader security culture: norms around cybersecurity become "the way we do things," improving consistent policy compliance (Amankwa et al., 2018; Amankwa et al., 2022).	Brief or one-off interventions have limited influence on organizational culture and norms. Security may be perceived as an added burden; employees revert to cultural defaults that may not prioritize secure behavior (Tang et al., 2016).
Reduction in Policy Violations	Empirical evidence suggests ongoing training promotes deeper internalization of policies, decreasing end-user policy violations (Amankwa et al., 2022). Repeated interventions help counter "training fatigue" by varied, tailored content (Lin et al., 2020).	Sporadic, superficial efforts lead to higher violation rates; users see policy compliance as optional or irrelevant. Minimal follow-up can result in employees forgetting or ignoring rules over time (Alotaibi et al., 2019).
Long-Term Incident Reduction	Regular interventions demonstrate a strong correlation with lower end-user-related security incidents (Alohali et al., 2018; Ani et al., 2019). Over time, employees become more alert to phishing, social engineering, and risky online behaviors.	Short-term, "check-the-box" programs often yield an initial spike in awareness, but any reduction in incidents is difficult to sustain. Users gradually forget new information, and incidents may remain frequent (Willison & Warkentin, 2013).

Quantitative Evidence of Decreased Security Incidents

Phishing Click Rates.

Multiple public and private-sector organizations recorded click rate declines ranging from 10% to 20% when periodic tests persisted for more than six months (Kävrestad et al., 2022; Reddy & Dietrich, 2017).

Policy Infractions.

A retail enterprise reported a 40% year-over-year drop in unauthorized credential-sharing after weekly quizzes and recognition programs were introduced (Carreiro et al., 2024; Obadofin, 2023).

Potential Downsides: Alert Fatigue and Diminishing Returns

Excessive or repetitive interventions risk desensitizing employees (Jansen & van Schaik, 2018). Reeves et al. (2021) describe cases where high simulation frequency prompted staff to dismiss legitimate security prompts, assuming they were part of ongoing drills. Such fatigue underscores the importance of varying content and scheduling (Almansoori et al., 2023; Taherdoost, 2024a).

Summary for RQ3

Longitudinal data strongly indicate that sustained interventions, supported by immediate feedback and updated threat scenarios, reduce employee-related security incidents and data breaches (He et al., 2020; Kävrestad et al., 2022). The most successful programs strategically rotate training formats to maintain engagement while avoiding user overload (Reeves et al., 2021).

Synthesis Across All Three Research Questions

Consolidated Observations from the Data

Targeted Training's Impact (RQ1).

Interactive, scenario-based, and role-specific education consistently outperforms static, generic training in reducing phishing success rates, unauthorized software use, and credential-sharing (Carreiro et al., 2024; Kävrestad et al., 2022; Reddy & Dietrich, 2017; Workman, 2021).

Policy-Culture Alignment (RQ2).

Security policies that align with an organization's core mission, whether around quality, trust, or patient care, promote significant reductions in workarounds and insider-driven risks (Alotaibi et al., 2019; Amankwa et al., 2018; Morgan, 2023).

Sustained Interventions (RQ3).

Continual exposure to simulated attacks, micro-trainings, and immediate feedback, when thoughtfully managed, effectively reduces the human factor gap by reinforcing secure behaviors (He et al., 2020; Kävrestad et al., 2022; Reeves et al., 2021).

Common Themes and Observed Challenges

Leadership Consistency.

Frequent references to managerial modeling underscore that top-down engagement can motivate employees to integrate security as a natural component of their work. (Ani et al., 2019; Georg-Schaffner & Prinz, 2022).

Resource Constraints.

Many organizations, especially smaller ones, cite cost and time as barriers to advanced gamification, VR, or AR-based solutions (Reddy & Dietrich, 2017; Taherdoost, 2024b).

Rapidly Evolving Threats.

Novel phishing and AI-enabled attacks necessitate periodic training content updates to remain effective, making real-time intelligence and threat tracking critical for sustained readiness (McManus, 2025).

Table 5

Summary of Key Findings by Research Question

Research Question	Main Takeaways	Representative References
RQ1: Interactive vs. Generic Training	- Interactive, tailored programs yield stronger retention and reduce phishing click rates more effectively than generic training. - Role-specific micro-trainings help employees correlate lessons with daily tasks.	(Ahmed et al., 2024); (Carreiro et al., 2024); (Kävrestad et al., 2022); (Nasir, 2023); (Reddy & Dietrich, 2017)
RQ2: Policy-Culture Alignment & Compliance	- Integrating security into the organization's overall identity lowers workarounds. - Leadership modeling promotes a climate where secure behaviors become a shared norm.	(Alotaibi et al., 2019); (Amankwa et al., 2018); (Amankwa et al., 2022); (Georg-Schaffner & Prinz, 2022); (Lin et al., 2020)
RQ3: Sustained Behavioral Interventions & Incident Rates	- Recurrent drills, micro-trainings, and immediate feedback produce enduring vigilance. - Careful scheduling prevents user fatigue, maintaining a balance between reminders and overload.	(Kävrestad et al., 2022); (Reeves et al., 2021); (Reddy & Dietrich, 2017); (Taherdoost, 2024a); (Willison & Warkentin, 2013)

Table 6

Cross-Industry Reported Impacts on the Human Factor Gap

Source	Industry	Intervention	Outcome and Gap Reduction
Ahmed et al. (2024)	Finance	Gamified phishing exercises	~15% drop in employee click rates, demonstrating tightened user awareness.
Carreiro et al. (2024)	Healthcare	Gamified micro-trainings + scenario-based drills	Fewer data mishandling incidents and enhanced staff motivation to learn new threats.
Kävrestad et al. (2022)	Public Agency	Contextual micro-trainings for phishing	Noticeable decline in repeated errors and improved knowledge retention.
Alotaibi et al. (2019)	Healthcare	Policy language tied to patient ethics	Staff are more conscientious in protecting patient data, bridging policy and practice.
Amankwa et al. (2018; 2022)	Manufacturing, Service	Quality-control-aligned security policies	30% drop in USB misuse, improved compliance rates credited to cultural integration.
Reddy & Dietrich (2017)	Technology Services	Monthly scenario-based modules	Reduced credential-sharing and unauthorized installs over 6-12 months.
Ahmed et al. (2024)	Finance	Gamified phishing exercises	~15% drop in employee click rates, demonstrating tightened user awareness.

Table 7

Empirical Findings from Key Studies

Study	Design and Sample	Focus or Intervention	Key Empirical Findings
Bevridge (2021)	- Quasi-experimental, mixed methods - *n* = 161 employees in a U.S. banking firm	Comparing high-realism vs. standard-realism cybersecurity scenario-based simulations.	- After six weeks, the high-realism group exhibited a phishing click rate of 8.7%, compared to 18.1% in the standard-realism group ($p < .05$). - Qualitative interviews showed greater retention of threat indicators among the high-realism cohort.
He et al. (2020)	- Quantitative field experiment - *n* = 230 employees across 3 organizations	Evidence-based malware training using live threat demonstrations and guided practice.	- Post-training malware recognition test scores averaged 80.3% (vs. 62.5% pre-training) ($p < .01$). - 71% of participants reported increased self-efficacy in identifying suspicious executable files; ~65% indicated they were "more likely" to report anomalies.
Morgan (2023)	- Qualitative, single-case study - Interviews with *n* = 20 Big Tech security professionals & policy experts	Exploring Big Tech's role in end-user cybersecurity, especially default tools and built-in protections.	- Participants estimated 50–60% of end-users underutilize available security features (e.g., 2FA, built-in VPN) despite being "free." - 70% stated that user "lack of awareness" was a bigger barrier than the technology itself; recommended "more consistent user education."

Raineri & Resig (2020)	- Survey-based correlational study - *n* = 105 small-business owners and managers in the U.S. Midwest	Short cybersecurity workshops + checklists aimed at boosting self-efficacy.	- Pre-workshop mean self-efficacy score = 3.15 on a 5-point scale. - Post-workshop mean self-efficacy = 4.02 ($p < .001$), reflecting a 0.87-point net increase. - 58% introduced at least one new security control (e.g., password manager) within three months.
Workman (2021)	- Exploratory, two-group quantitative survey - *n* = 154 employees in a mid-sized tech enterprise	Training mode comparison: e-learning modules vs. blended (instructor-led + e-learning).	- Blended training group improved phishing-email recognition by 16% (pre–post), while the e-learning-only group improved by 8.5% ($p < .05$). - Participants in the blended group rated sessions as "more engaging" and self-reported higher retention of best practices.

Limitations and Caveats

Reliance on Secondary Data

Since this study compiled findings exclusively from published sources, the reliability and generalizability of reported outcomes depend heavily on data collection methods in those primary studies (Kannelønning & Katsikas, 2023; Taherdoost, 2024a). Some organizations track only phishing simulations, while others log a broad spectrum of security events. Disparities in metrics can complicate direct comparisons (Almansoori et al., 2023).

Contextual Variations

The research spans organizations and industries with widely differing risk appetites, resources, and cultural norms (Carreiro et al., 2024; Haney & Lutters, 2020). A smaller firm

might achieve cost-effective improvements using simple micro-trainings, while a multinational enterprise may invest in expensive VR or AR modules. The replicability of results depends on aligning interventions with each organization's culture, size, and threat landscape (Alnajim et al., 2023; Reddy & Dietrich, 2017).

Evolving Threat Environment

Rapidly developing cyber-threats, ranging from AI-powered phishing to new forms of ransomware, present ongoing challenges to maintaining relevant training content (McManus, 2025; Shah et al., 2023). Annual modules cannot keep pace with threat evolution, underscoring the necessity for frequent updates and real-time adjustments (Reeves et al., 2021; Willison & Warkentin, 2013).

Potential for Alert Fatigue

Consistent reinforcement is beneficial. However, repeated simulations risk fatigue or desensitization if not carefully timed and varied (Jansen & van Schaik, 2018). Several studies warn that employees who dismiss frequent alerts as routine tests are likely to overlook authentic security warnings as well (Reeves et al., 2021).

Gaps in Measuring Long-Term Behavioral Change

While multiple studies documented immediate or short-term results from targeted training, few studies assessed whether these improvements lasted beyond six to twelve months (Kävrestad et al., 2022). Research calling for multi-year monitoring and repeated analytics highlights a current gap in understanding permanent shifts in security culture (Taherdoost, 2024a).

Conclusion of the Results

Utilizing empirical data from multiple industries, the reviewed sources highlight the multi-faceted strategies needed to close the human factor gap. Interactive, role-specific training consistently shows higher engagement and more resilient security outcomes compared to generic approaches (Beveridge, 2021; Carreiro et al., 2024; Donkeal Chandrashekar et al., 2024; Workman, 2021). Organizational culture and leadership play a critical role in shaping employee attitudes toward security, with culturally aligned policies driving greater compliance and fewer workarounds (Alotaibi et al., 2019; Georg-Schaffner & Prinz, 2022; Morgan, 2023). Finally, sustained behavioral interventions featuring recurring simulations and immediate feedback cycles maintain elevated vigilance, lowering incident rates if alert fatigue is carefully managed (He et al., 2020; Kävrestad et al., 2022; Reeves et al., 2021).

DISCUSSION

This section consolidates the study's results, considering the central thesis, the three guiding research questions (RQ1, RQ2, and RQ3), and the hypotheses that formed the foundation of each inquiry. The discussion highlights how interactive and targeted training (RQ1), culturally aligned policies (RQ2), and sustained behavioral interventions (RQ3) work in tandem to reduce the human-factor gap that exists between advanced technical safeguards and employees' day-to-day actions. It concludes by presenting a suggested framework that converts these insights into a unified, actionable model (Appendix A) and a second framework designed for assessing organizational security culture (Appendix B). Where possible, this section also provides more detailed numeric outcomes, both to illustrate tangible improvements and to acknowledge where results from different studies partially diverge or require context-specific adaptation.

Overview of the Discussion

The overarching goal of this thesis was to determine whether a human-centric cybersecurity strategy could effectively mitigate employee-driven vulnerabilities. The inquiry revolved around three specific research questions:

- RQ1: How does interactive, targeted cybersecurity training compare to traditional, generic training in improving employee awareness and secure behaviors?
- RQ2: How do information security policies aligned with organizational culture and norms influence user compliance and reduce security policy violations?
- RQ3: How effective are sustained behavioral interventions at decreasing employee-related security incidents?

Three corresponding sets of hypotheses were formulated to test how each strategy impacts user behavior. The subsections below interpret the study's results and place them within the context of established behavioral and motivational theories, offering a roadmap for theoretical understanding and practical application. Table 8 presents a snapshot of select numeric improvements derived from various case studies, highlighting the practical impacts of different interventions.

Table 8

Outcomes of Key Cybersecurity Interventions across Different Industries

Study / Reference	Context	Key Intervention	Phishing Click Rate / Policy Violations (Before)	Phishing Click Rate / Policy Violations (After)	Reported Change
Ahmed et al. (2024)	Finance	Gamified phishing exercises	Click rate: 30%	Click rate: 15%	15% overall drop

Carreiro et al. (2024)	Healthcare	Micro-trainings + scenario-based drills	Violations: 10/mo	Violations: 3/mo	70% decrease
Kävrestad et al. (2022)	Public agency	Context-based micro-training (phishing)	Click rate: 25%	Click rate: 10%	15% decrease
Reddy & Dietrich (2017)	Tech services	Hybrid (annual + monthly simulations)	Shadow IT usage: 12% of staff	4% of staff	8% fewer employees are using Shadow IT

These figures illustrate how different industries, including finance, healthcare, and public administration, experience measurable changes in user-driven risks depending on the type, frequency, and cultural fit of the interventions.

Addressing Research Question 1

How does interactive, targeted cybersecurity training compare to traditional, generic training in improving employee awareness and secure behaviors?

Key Findings and Interpretations

Findings from multiple sources confirm that interactive, context-specific training outperforms annual, generic modules in reducing phishing click rates, credential mishandling, and policy violations (Ahmed et al., 2024; Carreiro et al., 2024; Kävrestad, 2022). As shown in Table 8, targeted interventions reduced click rates by up to 15% in specific high-risk departments. Likewise, Beveridge (2021) documented that high-realism cybersecurity scenarios more than halved phishing click rates (from 18.1% to 8.7%). Additionally, Workman (2021) found that a blended training approach (instructor-led + e-learning) delivered a 16% improvement in threat recognition, nearly double the gain in the e-learning-only group.

Employees who participated in scenario-based exercises and received real-time feedback loops reported higher motivation and demonstrated more effective threat recognition skills than those who received static video lectures or text-based instructions. These improvements were especially obvious in finance or IT settings, where sophisticated threats exploit specialized knowledge gaps (Donkeal Chandrashekar et al., 2024). He et al. (2020) further illustrated that evidence-based malware training boosted post-training threat-recognition scores to an average of 80.3%, up from 62.5% pre-training.

Resource Constraints

Despite these advantages, the literature emphasizes that resource limitations, including budget, staff expertise, and technology infrastructure, can impede the implementation of advanced methods like VR simulations or gamified drills (Alnajim et al., 2023; Haney & Lutters, 2020). However, as Table 8 also indicates, even modestly scaled approaches, like micro-trainings, short role-based quizzes, and just-in-time prompts, led to improved outcomes relative to one-size-fits-all sessions (Reddy & Dietrich, 2017; Taherdoost, 2024a). Raineri and Resig (2020) demonstrate that even brief workshops and checklists can significantly increase self-efficacy among small-business owners, showing that interactive approaches can be adapted affordably.

Implications for the Human-Factor Gap

Overall, targeted interactive training narrows the human-factor gap by actively engaging employees, boosting their self-efficacy (Bandura, 1977), and enabling them to detect and respond to emerging and evolving threats more confidently (Kävrestad et al., 2022; Raineri & Resig, 2020). While immersive simulations may produce the most significant improvements, the results

suggest that even partial adoption of scenario-based or role-specific training can enhance user vigilance and preparedness, particularly when paired with immediate feedback loops.

Addressing Research Question 2

How do information security policies aligned with organizational culture and norms influence user compliance and reduce security policy violations?

Role of Culture in Security Compliance

Data from the results consistently highlights how cultural alignment can transform formal rules into normative behaviors (Alotaibi et al., 2019; Lin et al., 2020). When an organization embeds security policies within its guiding values, such as patient welfare, product quality, or customer loyalty, employees perceive these directives as supportive rather than restrictive (Amankwa et al., 2018). This perception drastically lowers the number of workarounds, which often develop when staff believe security mandates conflict with productivity objectives (Spivey & McIlveene, 2024).

Leadership Consistency and Modeling

A recurring theme is that leadership modeling magnifies cultural alignment (Ani et al., 2019; D'Arcy et al., 2009). Employees who witness senior managers practicing secure behaviors, like using encryption, employing multifactor authentication, or being vigilant about shadow IT, internalize these actions as part of the organizational fabric (Georg-Schaffner & Prinz, 2022). Conversely, apparent or perceived managerial inconsistencies can undermine policy adherence. Staff may assume shortcuts are acceptable if higher-ups ignore established processes. Morgan (2023) notes that even when organizations supply robust security tools, consistent use often depends on how well organizational leaders promote their adoption and demonstrate supportive values.

Bridging the Gap with Cultural Alignment

Align policies with everyday values and ensure management consistently positions security as a collective responsibility. This synergy reduces the human-factor gap by embedding secure protocols into daily workflows, making cybersecurity an ethical and operational norm (McKnight & Warkentin, 2020; Obadofin, 2023). By doing this, policy compliance becomes second nature rather than an external imposition or check-the-box exercise.

Addressing Research Question 3

How effective are sustained behavioral interventions at decreasing employee-related security incidents?

Importance of Ongoing Exposure and Feedback

Studies broadly agree that one-time training seldom develops lasting improvements in employees' behaviors (Reddy & Dietrich, 2017). On the other hand, periodic interventions, like monthly phishing simulations, short refresher quizzes, and immediate feedback, help maintain user awareness of current threats (Chockalingam et al., 2021; Kävrestad et al., 2022). As shown in Table 8, ongoing simulations presented at carefully timed intervals, rather than sporadic, once-a-year sessions, correlated with drops of up to 15% in click rates and substantial reductions in policy breaches. Workman (2021) likewise found that continuous blended training, rather than a single module, built deeper engagement over time.

Avoiding Alert Fatigue and Diminishing Returns

However, alert fatigue remains a risk. Repeated or overly frequent drills can lead employees to dismiss warnings or assume they are part of yet another simulation (Jansen & van Schaik, 2018; Reeves et al., 2021). Organizations need to balance the frequency and variety of these exercises to keep staff engaged and alert (Almansoori et al., 2023). Combining micro-

trainings with periodic scenario-based workshops and offering positive incentives, such as recognition for correctly identifying phishing attempts, can help mitigate complacency (Carreiro et al., 2024; Spivey & McIlveene, 2024). He et al. (2020) demonstrated that sustained interventions also reinforce self-efficacy: over 70% of employees in their study reported feeling more capable of spotting and reporting malicious software post-training.

Sustaining Long-Term Readiness

When varied and spaced appropriately, sustained behavioral interventions reinforce employees' resilience to evolving threats (Haney & Lutters, 2020). They also encourage proactive reporting as employees learn to spot unusual network activity or suspicious emails early (Donkeal Chandrashekar et al., 2024). Continuous engagement is critical for addressing the human-factor gap, ensuring that employees consistently serve as a reliable line of defense rather than occasional trainees (Kävrestad et al., 2022).

Interpretation of the Results

Integrating Training, Culture, and Reinforcement

The primary result of this study, with regard to RQ1, RQ2, and RQ3, is that interactive training and culturally aligned policies are most effective when consistently reinforced. Employees who receive engaging, role-specific training (RQ1) and are supported by leadership-driven, culturally aligned policies (RQ2) maintain their alertness and vigilance when their skills are reinforced through continuous behavioral interventions (RQ3). This interdependence emphasizes that it is best to deliver employee-focused training as part of a holistic strategy rather than as standalone initiatives.

Original Contributions and Insights

While prior research often addresses the topics covered in this study- training methodology, policy alignment, and feedback or interventions- individually, this study focuses on the interdependence of all three in creating effective and long-lasting outcomes. By integrating targeted and interactive training methods, culture-based policies, sustained and timely interventions, and feedback, organizations can create an employee-driven security environment that addresses immediate risks and builds long-term protective security habits. In smaller contexts, Raineri and Resig (2020) highlight how straightforward workshops can serve as a cost-effective entry point, while Beveridge (2021) emphasizes that adding realistic detail to training can produce more significant and lasting engagement.

Theoretical and Practical Implications

Theoretical Implications

The results reinforce multiple behavioral theories:

- Theory of Planned Behavior (Ajzen, 1991): Demonstrates how leadership cues and peer norms strongly shape employees' compliance habits.
- Self-Efficacy Theory (Bandura, 1977): Underscores how immersive or scenario-based simulations build user confidence in handling threats (He et al., 2020).
- Protection Motivation Theory (Haag et al., 2021): Explains why measured fear-appeals, balanced by actionable coping strategies, motivate employees to remain vigilant.
- Deterrence Theory (D'Arcy et al., 2009): Shows that penalty-based tactics can promote initial compliance but are insufficient without supportive norms and skill-building to maintain long-term adherence.

This research study evaluated the empirical outcomes within the context of these frameworks, clarifying the social, cognitive, and motivational dynamics that foster consistent security behaviors.

Practical Implications

From an organization's standpoint, a few actionable guidelines were identified:

- Adopt Interactive, Role-Specific Training
    - Concentrate resources on high-risk roles like finance, information technology, and other data-heavy departments.
    - Even basic micro-trainings or short, scenario-based exercises significantly reduce vulnerabilities if well-timed (Reddy & Dietrich, 2017).
- Align Security Policies with Cultural Norms
    - Invite staff from different levels to co-develop policies that fit daily workflows and reflect shared values.
    - Encourage leadership to demonstrate that secure practices matter at every level of the organization, from frontline employees to executives alike (Morgan, 2023).
- Reinforce Secure Behaviors Continuously
    - Schedule monthly or quarterly phishing simulations and micro-lessons, updating content to reflect the newest threat vectors (He et al., 2020).
    - Use varied formats, such as videos, quizzes, and scenario practice, to avoid alert fatigue or repetitive monotony (Workman, 2021).
- Support Positive Organizational Climate
    - Publicly acknowledge employees who demonstrate the desired behaviors through demonstrated security awareness or early detection of suspicious activities.

- Emphasize constructive feedback rather than punitive reactions, promoting a culture of learning and open reporting.

These steps address the human factor in IS and cybersecurity, reducing the chances that an employee's action or inaction will undermine advanced technical tools or policies.

Evaluating the Hypotheses

Corresponding with the three core research questions, the study formulated three sets of specific hypotheses:

1. Targeted Cybersecurity Training vs. Traditional, Generic Training
    - Null (H_0): Employees who receive interactive, targeted cybersecurity education exhibit no significantly different security behaviors than those who receive traditional, generic training.
    - Alternative (H_1): Employees who receive interactive, targeted cybersecurity education exhibit significantly different security behavior outcomes than those who receive traditional, generic training.

    Results: Studies like Kävrestad et al. (2022), Beveridge (2021), and Carreiro et al. (2024) show phishing click rates or policy infractions dropping notably post-training (up to 15–70%), thereby refuting H_0 and confirming H_1.
2. Influence of Organizational Culture on Compliance
    - Null (H_0): Security policies aligned with organizational culture do not significantly influence employees' compliance with security policies.
    - Alternative (H_1): Security policies aligned with organizational culture do significantly influence employees' compliance with security policies.

Results: Multiple examples (Alotaibi et al., 2019; Georg-Schaffner & Prinz, 2022; Morgan, 2023) highlight consistent managerial modeling, embedding security in daily routines, and reinforcing norms, validating H_1 over H_0.

3. Impact of Sustained Behavioral Interventions
    - Null (H_0): Sustained behavioral interventions have no significant effect in reducing employee-related security incidents.
    - Alternative (H_1): Sustained behavioral interventions have a significant effect in reducing employee-related security incidents.

    Results: As Table 8 indicates, repeated simulations and micro-trainings correlate with notable drops in click rates and policy slips, disproving H_0 and demonstrating H_1 to be true. Carefully paced scheduling prevents alert fatigue and ensures lasting engagement (He et al., 2020; Workman, 2021).

Across all three hypotheses, the alternative propositions are consistently supported by empirical results and theoretical models.

Limitations and Caveats

Despite these promising findings, several caveats do exist:

- Dependence on Secondary Data

  This research consolidated existing studies, which may vary in data collection rigor or fail to capture certain contextual factors (Kannelønning & Katsikas, 2023).

- Contextual Variability Across Organizations

  Security challenges differ by industry, the organization's size, and resource availability. For example, an advanced gamified approach may excel in one context but be cost-prohibitive or less relevant in another (Alnajim et al., 2023; Reddy & Dietrich, 2017).

- Rapidly Evolving Threat Landscape

  AI-driven phishing and emerging social engineering tactics can quickly overshadow static training programs (McManus, 2025; Shah et al., 2023). Ongoing updates are necessary for maintaining relevance.

- Limited Long-Term Evaluations

  While many studies observe short-to-medium-term gains, few examine multi-year impacts, staff turnover, or shifts in organizational culture (Kävrestad et al., 2022; Shah et al., 2023).

- Potential Contradictions or Partial Results

  A minority of sources reported minimal differences between generic and targeted training, possibly due to inconsistent leadership support or disjointed policy frameworks.

Conclusion of the Discussion

This thesis highlights that interactive, targeted training, culturally aligned policies, and sustained behavioral interventions offer a powerful, human-centric approach to modern IS and cybersecurity. Rather than treating each component as a stand-alone fix, the combined evidence shows that a truly robust defense emerges when organizations integrate hands-on learning with leaders who actively model secure behaviors, and who reinforce that culture through regular reminders and evolving simulations.

By combining insights from the literature review with real-world results, it is clear that a human-centric security strategy makes employees feel more confident. When they are confident in their abilities, they become better at identifying and responding to threats, significantly reducing common errors and creating an environment where security is embedded in everyday tasks. Small-scale micro-trainings or periodic, scenario-based exercises will also help employees

stay alert and invested in keeping the organization safe, as demonstrated by He et al. (2020), Raineri and Resig (2020), and Workman (2021).

However, implementing a human-centric IS and cybersecurity strategy requires thoughtful planning and customization tailored to the organization's specific needs. Not every organization has the resources to implement VR or AR simulation or mass gamification (Beveridge, 2021). Yet most can achieve measurable benefits through less costly methods if they are aligned with the organization's culture, workflows, and employees' daily work. Aside from addressing specific vulnerabilities, such as phishing or the use of unauthorized programs, organizations need to plan to keep employees interested without creating alert overload or burnout (Reeves et al., 2021).

Appendix A proposes an integrated human-centric framework that synthesizes the core findings and implications of this thesis to aid organizations in navigating the implementation of human-centric IS and cybersecurity strategy. It consists of seven domains that were built to translate the theoretical foundations and findings of the case studies into actionable recommendations. The domains direct the creation of interactive training modules tailored to specific needs, culturally sensitive policies, and ongoing interventions that address the unique constraints of each organization. Organizations can effectively bridge the human-factor gap by implementing a strategy that consistently engages employees and leaders and can adapt to stay current with new security threats under one integrated framework. This will result in a workforce that is prepared for the security issues of the present and responsive to future needs.

Aligning with the human-centric focus of this thesis, Appendix B presents a framework to audit employees' perceptions, experiences, and engagement with IS and cybersecurity measures. It utilizes this study's theoretical foundations and empirical insights to offer a practical approach

for systematically assessing leadership visibility, policy alignment, training effectiveness, and communication channels within the organization. This audit's questions utilize Likert-scale ratings and open-ended prompts. It is designed to aid in diagnosing organizational culture, pinpointing gaps, and highlighting strengths. Combined with the strategic interventions outlined in this thesis, this auditing tool can facilitate ongoing improvements, support secure practices, and promote a culture that is attentive to emerging and evolving cyber threats.

FINDINGS

Findings from this research study are summarized into three sections that align with the research questions. This section provides a logical overview of key findings, explaining how interactive training surpasses generic techniques in making users more aware, how culture-based policies minimize policy violations, and how repeated reinforcements maintain employee focus and concentration. It also provides recommendations for future research.

RQ1: The Efficacy of Targeted Cybersecurity Training

Several studies have identified that interactive, context-specific training develops safer employee behaviors more effectively than traditional, generic modules. (Carreiro et al., 2024; Kävrestad et al., 2022). As previously explained, simulation-based exercises immerse employees in real-life scenarios of threats, making them more confident in reporting and detecting malicious activities (Taherdoost, 2024b). Unlike standard check-the-box sessions, these targeted methods encourage deeper engagement, yield lower phishing click rates, and reduce instances of policy non-compliance over the long term (Reddy & Dietrich, 2017). In particular, Beveridge (2021) demonstrated that high-realism simulations cut phishing click rates from 18.1% to 8.7%, while

Workman (2021) found that blended formats (instructor-led + e-learning) nearly doubled the phishing detection capabilities compared to online-only modules.

Additionally, He et al. (2020) observed that providing evidence-based malware training raised average threat-recognition scores from 62.5% to 80.3%, boosting users' awareness and their likelihood of reporting potential breaches. These gains in self-efficacy are not limited to large organizations; Raineri and Resig (2020) reported a 0.87-point increase (on a five-point scale) in cybersecurity self-efficacy among small business owners after brief workshops, indicating that well-planned, interactive approaches can also be practical in resource-constrained settings.

However, practical concerns remain. Many small and medium-sized enterprises lack the necessary funds or expertise to adopt advanced gamification or immersion-based techniques (Alnajim et al., 2023; Haney & Lutters, 2020). Additionally, highly specialized solutions like VR and AR platforms demand substantial maintenance and frequent content updates to remain relevant against emerging and evolving threats (Donkeal Chandrashekar et al., 2024). This means that organizations must weigh the relative benefits of these innovative methods against the greater upfront and ongoing costs of development, maintenance, and management (Nasir, 2023). Nevertheless, simpler methods, such as short, scenario-based modules, have also proven highly impactful when delivered consistently (Reddy & Dietrich, 2017).

RQ2: The Role of Cultural Alignment in Policy Compliance

Aligning security policies with the organization's culture and norms is frequently associated with higher policy adherence (Alotaibi et al., 2019; Lin et al., 2020). In scenarios where leadership promotes and visibly models secure practices, employees express an increased sense of ownership, reducing the likelihood of risky workarounds (Amankwa et al., 2018; Georg-

Schaffner & Prinz, 2022). Equally important is the evidence that when employees understand how data protection efforts mirror broader organizational goals, such as nurturing customer trust or maintaining product integrity, they more willingly comply with policy requirements (Spivey & McIlveene, 2024; Tang et al., 2016). Similarly, Morgan (2023) notes that even robust tools and default protections offered by large technology providers can be underutilized if organizational leaders fail to promote a culture of consistent adoption and user awareness.

In contrast, confusing or overly stringent security guidelines that clash with day-to-day priorities often encourage the development of counterproductive workarounds (D'Arcy et al., 2009; Willison & Warkentin, 2013). For example, high-pressure workplaces that emphasize speed and productivity can inadvertently prompt individuals to bypass security checks (Haney & Lutters, 2020). Thus, the key message stands: an integrated approach, where policy directives, managerial conduct, and the existing cultural ethos complement rather than contradict each other, drives more consistent adherence (Triplett, 2022).

RQ3: The Necessity of Sustained Behavioral Reinforcement

The literature repeatedly highlights that a single training session only provides short-lived improvements in user diligence (Reddy & Dietrich, 2017; Willison & Warkentin, 2013). Sustained interventions, such as periodic phishing simulations, ongoing micro-trainings, and timely feedback, allow employees to reinforce newly learned skills over time (Kävrestad et al., 2022). In multiple case studies, these continuous refreshers were tied to notable drops in recurrent policy violations, as employees developed deeper internalizations of how attacks manifest in practice (Carreiro et al., 2024; Reeves et al., 2021). He et al. (2020) similarly noted how repeated exposure to simulations and real-time threat demonstrations boosted user vigilance and willingness to report suspicious software.

Nevertheless, organizations must carefully control the frequency and nature of these reinforcements. Studies indicate that excessive simulations or unrelenting fear-based messages may induce alert fatigue, diminishing user responsiveness to real incidents (Almansoori et al., 2023; Reeves et al., 2021). A carefully balanced schedule that rotates through various threat scenarios, leverages diverse training platforms, and provides immediate feedback appears to be the most effective in maintaining consistent employee alertness (Spivey & McIlveene, 2024; Taherdoost, 2024a). Additionally, Workman (2021) emphasizes that blending different training modes can help employees retain knowledge more effectively over time, while Raineri and Resig (2020) show how short, repeated interventions can gradually build self-efficacy for those with limited cybersecurity backgrounds.

Recommendations for Future Research

Longitudinal Studies on Intervention Effectiveness

While much of the current literature focuses on shorter-term, three to six month, measurements of improved cybersecurity behaviors (Carreiro et al., 2024; Kävrestad et al., 2022), the evidence base remains limited regarding whether these gains continue under changing organizational conditions or evolving threats (Chockalingam et al., 2021; Donkeal Chandrashekar et al., 2024). Employees may demonstrate increased vigilance immediately following gamified or scenario-based training. However, there is a lack of studies assessing if those enhanced behaviors remain stable over one to two years, or even beyond, once initial enthusiasm dissipates or leadership priorities shift (Haney & Lutters, 2020; Shah et al., 2023).

Longitudinal research should capture repeated measurements of user compliance, incident rates, and organizational culture changes across extended timeframes (Taherdoost, 2024a; Willison & Warkentin, 2013). One approach is periodically evaluating phishing click

rates, policy violations, user attitudes, and self-efficacy scores to gauge whether short-term knowledge gains transform into lasting cultural norms (Bulgurcu et al., 2010; Obadofin, 2023). Additionally, studies with multiple data collection iterations could monitor how external factors, such as staff turnover, role reassignments, or new cyber threat trends, affect employee behavior patterns (Kannelønning & Katsikas, 2023; Reeves et al., 2021).

A longitudinal study on the effectiveness of various intervention methods could help determine whether organizations that have implemented a human-centric framework achieve better long-term outcomes compared to those using generic or ad hoc strategies (Anant et al., 2020; McManus, 2025). For instance, a multi-year evaluation of role-specific training and culturally-aligned policies might demonstrate the long-term effectiveness of repeated micro-training sessions in mitigating complacency and alert fatigue (Almansoori et al., 2023; Spivey & McIlveene, 2024). Examining the results of these interventions over a longer period may also identify at what point diminishing returns begin to appear, providing critical insights into the optimal frequency and diversity of training required to maintain employee engagement (Kävrestad, 2022; Reeves et al., 2021).

Together, these studies can strengthen claims by pairing quantitative metrics with qualitative perspectives that have been collected at multiple intervals over longer periods (Morgan, 2023; Reddy & Dietrich, 2017). Combining these methods over several iterative cycles could also determine the ongoing effectiveness of IS and cybersecurity-related training as the organization experiences changes, such as budget reductions, leadership transitions, or the implementation of new technologies (Georg-Schaffner & Prinz, 2022; Lin et al., 2020). Overall, substantial longitudinal research studies are needed to confirm whether early gains in security

awareness reflect short-lived compliance surges or if they indicate a meaningful transformation of organizational culture and employee behaviors (Amankwa et al., 2022; Reeves et al., 2021).

To address the limited availability of long-term data, future work should track employees' security behaviors for multiple years post-training and policy implementation. These studies could identify how habits evolve when employees are promoted, switch roles, or respond to newly emerging threats.

Cost-Benefit Analyses of Training Methods

The findings of this study revealed that interactive, role-specific training methods can significantly improve employee security awareness and reduce policy violations (Carreiro et al., 2024; Kävrestad et al., 2022). However, relatively few researchers have investigated the actual return on investment (ROI) of these approaches over time, particularly when considering small or resource-constrained organizations (Haney & Lutters, 2020; Nasir, 2023). Future research should incorporate cost-benefit analyses that compare the potential savings from avoided security incidents, data breaches, and reduced downtime against the implementation and operational costs of more advanced training methods.

In practice, these studies should utilize industry and compliance-related frameworks to build and track outcome metrics (Alotaibi et al., 2019). In doing so, organizations would have a foundation to base annual operational costs for content updates, software licenses, and instructor hours upon (Alnajim et al., 2023). These financial data points can be used to calculate ROI by comparing them with quantitative security metrics over time (Carreiro et al., 2024; Reddy & Dietrich, 2017). In addition, qualitative indicators, including staff surveys on training engagement and reported ease of compliance, would capture the non-monetary benefits and help to build a holistic understanding of the long-term ROI. By examining economic and perceptual

factors together, this future work could inform decision-makers about which training methods deliver the most sustained outcomes relative to their cost (Beveridge, 2021; Donkeal Chandrashekar et al., 2024).

From an organizational perspective, a clearer sense of ROI may result in accelerating the adoption of advanced training methods by providing evidence-based justifications that are readily presentable to the organization's leadership (Shah et al., 2023). Whether focusing on smaller firms or multinational corporations, results from cost-benefit analyses would clarify to what extent organizations can spend on innovative training tools before the ROI is achieved (Alnajim et al., 2023; Taherdoost, 2024a). This line of inquiry could deepen stakeholders' confidence in allocating resources for security awareness initiatives.

While immersive gamified platforms show promise, there is a lack of granular data on how to balance these costs against potential savings from reduced security incidents and data breaches. Future quantitative research could evaluate the ROI for various training models, ranging from basic micro-trainings to advanced VR or AR environments.

Multi-Cultural and Multi-National Contexts

Although the need for culturally aligned security policies is well established (Alotaibi et al., 2019; Lin et al., 2020), the literature suggests that implementing these policies across international sites remains challenging (Kshetri & Alcantara, 2015). Organizations functioning in multiple regions often face diverse regulatory frameworks, sociocultural norms, and languages, which complicate the consistency of policy enforcement (Tang et al., 2016). Researchers should investigate methods of tailoring training modules and policies to employees with varying perceptions of authority, privacy, and risk (Amankwa et al., 2018).

This research could also track multi-site deployments to see how cross-border teams handle locally adapted training, leadership, and culturally sensitive threat simulations (McKnight & Warkentin, 2020; Morgan, 2023). A multinational healthcare provider, for example, might adjust encryption protocols to meet a country's specific confidentiality requirements while maintaining a unified security standard. Qualitative insights from interviews or focus groups can help organizations identify the cultural factors that affect policy adoption, while quantitative metrics can demonstrate measurable improvements (Carreiro et al., 2024; Donkeal Chandrashekar et al., 2024). This approach would allow international organizations to identify the necessary changes to achieve consistent security outcomes while respecting local cultures.

Future research should investigate whether interactive interventions are more effective in specific cultural contexts. Some employees may favor competitive exercises with rewards, while others might find them trivializing of serious threats (Chockalingam et al., 2021). Recognizing these cross-cultural differences will enable organizations to tailor the training methods and content to be both globally consistent and locally relevant (Kshetri & Alcantara, 2015; Triplett, 2022).

Considering the substantial impact that cultural alignment has on policy compliance, it is recommended that future research explore how multinational organizations handle differing cultural viewpoints on authority, risk, and individualism. Empirical studies may be able to identify effective methods for tailoring security protocols to accommodate diverse employee groups.

Adaptive Training and Alert Fatigue Management

Maintaining an engaged workforce is challenging because overly frequent messages and repetitive drills can desensitize users (Almansoori et al., 2023; Reeves et al., 2021). This

necessitates further research into adaptive training protocols that dynamically adjust their difficulty and frequency based on user performance and unique risk profiles (He et al., 2020). This approach could incorporate artificial intelligence, machine learning, or rule-based logic to determine the most effective timing and format of quizzes, micro-trainings, and simulated attacks, reducing the occurrences of alert fatigue (Kävrestad, 2022).

Future research should examine how adaptive training systems affect short-term responsiveness and long-term retention of positive security habits (Willison & Warkentin, 2013). By targeting employees based on factors like role-specific risk or past click-rate errors, researchers can generate insights on whether personalization leads to a measurable drop in alert fatigue or complacency (Carreiro et al., 2024; Taherdoost, 2024a). Additionally, comparisons across multiple industries could pinpoint which threat types and training intervals are most likely to sustain vigilance in specific industries or employee roles (Alotaibi et al., 2019; Workman, 2021).

Implementing adaptive training would also necessitate better real-time measurement capabilities to monitor user responses, whether that is an immediate click on a suspicious link or a delayed reaction indicating further confusion (Chockalingam et al., 2021). Although some employees may initially resist data-driven adjustments to their training program, transparent communication from leadership, combined with constructive feedback on user performance, may address these concerns (Lin et al., 2020; Spivey & McIlveene, 2024). Observational data from multi-month pilots or multi-year field studies could thus validate whether adaptive protocols maintain heightened awareness as compared to conventional, one-size-fits-all programs (Reddy & Dietrich, 2017; Shah et al., 2023).

Additional studies could investigate adaptive training platforms capable of dynamically adjusting difficulty, frequency, and content to mitigate the risk of alert fatigue. Such systems would tailor interventions to an employee's performance history and demonstrated threat recognition skills.

Comprehensive Implementation Frameworks for Smaller Organizations

While larger organizations may possess the resources required to implement and maintain VR and AR-based simulations or to update gamified exercises continually, smaller organizations often lack the budget and specialized staff necessary (Alnajim et al., 2023; Haney & Lutters, 2020). To address this disparity, future research should focus on creating a scalable and cost-effective implementation framework, like the one proposed in Appendix A, that small and medium-sized organizations (SMEs) can adopt to reinforce security behavior with a lower investment (Nasir, 2023). This framework could utilize scalable, yet simplified micro-training structures, short scenario-based exercises, or partial gamification methods that yield measurable improvements even with limited investment (Reddy & Dietrich, 2017).

Empirical comparisons between low-complexity approaches, like text-based quizzes and policy reminders, would establish how effectively SMEs can reduce their risk exposure on limited budgets (Amankwa et al., 2022; Kävrestad et al., 2022). Pairing these basic interventions with leadership support and culturally aligned policies may result in a strong, integrated approach that still leverages best practices often observed by larger organizations (Alotaibi et al., 2019; Georg-Schaffner & Prinz, 2022). To benefit resource-constrained organizations, research can further identify which frameworks, or portions thereof, deliver the most significant impact by tracking and reporting on relevant security metrics (Beveridge, 2021; He et al., 2020).

Additionally, implementing programs incrementally in SMEs could enable organizations to gradually introduce advanced techniques rather than all at once (Donkeal Chandrashekar et al., 2024). Longitudinal data collected from these incremental implementations can be utilized to adapt or modify existing frameworks, mitigating workforce fatigue, ensuring cost viability, and maintaining consistent management support (Spivey & McIlveene, 2024). A well-structured framework tailored to an environment with limited resources would enable SMEs to adopt a human-centric security strategy without compromising core business objectives (McManus, 2025; Reeves et al., 2021).

Conclusion Of the Findings

The research findings demonstrate that investing in targeted training, culturally aligned policies, and sustained behavioral interventions can fortify employees and enhance compliance with IS and cybersecurity policies and procedures. This will increase organizational resilience against emerging and evolving threats. Specifically, the results show that interactive training engages users more effectively than generic approaches, while culturally aligned policies reduce workarounds by developing secure behaviors and habits. Additionally, ongoing and carefully spaced behavioral interventions, combined with timely feedback, help maintain awareness without causing alert fatigue, leading to sustained user attention over time.

Future research should focus on extending these insights through:

- Longitudinal assessments that track how short-term security gains hold up over multiple years and organizational changes.
- Cross-cultural and multi-national studies examining how training and policy frameworks adapt to different work norms worldwide.

- Cost-benefit analyses that clarify the potential return on investment for resource-intensive methods.
- Adaptive training strategies capable of dynamically tailoring content to mitigate boredom and overexposure.
- Scaled-down frameworks for smaller enterprises to ensure that advanced security interventions remain attainable even where budgets are limited.

Together, these recommended areas of research hold the potential to identify the most effective ways to institutionalize a lasting, human-centric security culture across diverse industries and regions. This reinforces the fact that technology alone cannot fully safeguard an organization without the ongoing commitment and proactive engagement of its workforce.

LIST OF REFERENCES

Ahmed, Y., Ezealor, M., Mahmoud, H., Azad, M., Farah, M., & Yousefi, M. (2024, Apr 13). *Enhancing security awareness through gamified approaches.* arXiv - Cornell University. https://arxiv.org/html/2404.09052v1

Ajzen, I. (1991). The theory of planned behavior. *Organizational Behavior and Human Decision Processes, 50*(2), 179-211. https://doi.org/10.1016/0749-5978(91)90020-T

Almansoori, A., Al-Emran, M., & Shaalan, K. (2023). Exploring the frontiers of cybersecurity behavior: A systematic review of studies and theories. *Applied Sciences, 13*(9), 5700. https://doi.org/10.3390/app13095700

Alnajim, A. M., Habib, S., Islam, M., AlRawashdeh, H., & Wasim, M. (2023). Exploring cybersecurity education and training techniques: A comprehensive review of traditional, virtual reality, and augmented reality approaches. *Symmetry, 15*(12), 2175. https://doi.org/10.3390/sym15122175

Alohali, M., Clarke, N., Li, F., & Furnell, S. (2018). Identifying and predicting the factors affecting end-users' risk-taking behavior. *Information and Computer Security, 26*(3), 306-326. https://doi.org/10.1108/ICS-03-2018-0037

Alotaibi, M. J., Furnell, S., & Clarke, N. (2019). A framework for reporting and dealing with end-user security policy compliance. *Information Management & Computer Security, 27*(1), 2-25. https://doi.org/10.1108/ICS-12-2017-0097

Amankwa, E., Loock, M., & Kritzinger, E. (2018). Establishing information security policy compliance culture in organizations. *Information and Computer Security, 26*(4), 420-436. https://doi.org/10.1108/ICS-09-2017-0063

Amankwa, E., Loock, M., & Kritzinger, E. (2022). The determinants of an information security policy compliance culture in organisations: The combined effects of organisational and behavioural factors. *Information and Computer Security, 30*(4), 583-614. https://doi.org/10.1108/ICS-10-2021-0169

Anant, V., Banerjee, S., Boehm, J., & Li, K. (2020, Jul 7). *A dual cybersecurity mindset for the next normal*. McKinsey & Company. https://www.mckinsey.com/business-functions/risk/our-insights/a-dual-cybersecurity-mindset-for-the-next-normal

Ani, U., He, H., & Tiwari, A. (2019). Human factor security: Evaluating the cybersecurity capacity of the industrial workforce. *Journal of Systems and Information Technology, 21*(1), 2-35. https://doi.org/10.1108/JSIT-02-2018-0028

Bandura, A. (1977). Self-efficacy: Toward a unifying theory of behavioral change. *Psychological Review, 84*(2), 191-215. https://doi.org/10.1037/0033-295X.84.2.191

Beveridge, R. (2021). *Efficacy of increasing realism in cybersecurity training.* ProQuest Dissertations & Theses.

Bulgurcu, B., Cavusoglu, H., & Benbasat, I. (2010). Information security policy compliance: An empirical study of rationality-based beliefs and information security awareness. *MIS Quarterly, 34*(3), 523-548. https://doi.org/10.2307/25750690

Campean, S. (2019). The human factor at the center of a cyber security culture. *International Journal of Information Security and Cybercrime, 8*(1), 51-58. https://doi.org/10.19107/IJISC.2019.01.07

Carreiro, A., Silva, C., & Antunes, M. (2024). The use of gamification on cybersecurity awareness of healthcare professionals. *Procedia Computer Science, 239*, 526-533. https://doi.org/10.1016/j.procs.2024.06.202

Chockalingam, S., Esnoul, C., Simensen, J., & Sechi, F. (2021). Serious games for cyber security: Elicitation and analysis of end-user preferences and organisational needs. *European Conference on Cyber Warfare and Security*, 80-89. https://doi.org/10.34190/EWS.21.043

D'Arcy, J., Hovav, A., & Galletta, D. (2009). User awareness of security countermeasures and Its impact on information systems misuse: a deterrence approach. *Information Systems Research, 20*(1), 79-98. https://doi.org/10.1287/isre.1070.0160

Donkeal Chandrashekar, N., Lee, A., Azab, M., & Gracanin, D. (2024). Understanding user behavior for enhancing cybersecurity training with immersive gamified platforms. *Information, 15*(12), 814. https://doi.org/10.3390/info15120814

Georg-Schaffner, L., & Prinz, E. (2022, Dec). Corporate management boards' information security orientation: an analysis of cybersecurity incidents in DAX 30 companies. *Journal of Management & Governance, 26*(4), 1375-1408. https://doi.org/10.1007/s10997-021-09588-4

Haag, S., Siponen, M., & Lio, F. (2021). Protection motivation theory in information systems security research: A review of the past and a road map for the future. *Data Base for Advances in Information Systems, 52*, 25-67. https://doi.org/10.1145/3462766.3462770

Haney, J., & Lutters, W. (2020). Security awareness training for the workforce: Moving beyond "check-the-box" compliance. *Computer, 53*(10). https://doi.org/10.1109/mc.2020.3001959

He, W., Ash, I., Anwar, M., Li, L., Yuan, X., Xu, L., & Tian, X. (2020). Improving employees' intellectual capacity for cybersecurity through evidence-based malware training. *Journal of Intellectual Capital, 21*(2), 203-213. https://doi.org/10.1108/JIC-05-2019-0112

Hofstede, G., Neuijen, B., Ohayv, D., & Sanders, G. (1990). Measuring organizational cultures: A qualitative and quantitative study across twenty cases. *Administrative Science Quarterly, 35*(2), 286-316. https://doi.org/10.2307/2393392

Jansen, J., & van Schaik, P. (2018). Persuading end users to act cautiously online: a fear appeals study on phishing. *Information and Computer Security, 26*(3), 264-276. https://doi.org/10.1108/ICS-03-2018-0038

Kannelønning, K., & Katsikas, S. K. (2023). A systematic literature review of how cybersecurity-related behavior has been assessed. *Information and Computer Security, 31*(4), 463-477. https://doi.org/10.1108/ICS-08-2022-0139

Karjalain, M., & Siponen, M. (2011). Toward a new meta-theory for designing information systems (IS) security training approaches. *Journal of the Association for Information Systems, 12*(8), 518-555. https://doi.org/10.17705/1jais.00274

Kävrestad, J. (2022). *Context-based micro-training: Enhancing cybersecurity training for end-users.* PhD dissertation, University of Skövde. https://urn.kb.se/resolve?urn=urn:nbn:se:his:diva-21819

Kävrestad, J., Hagber, A., Nohlberg, M., Rambusch, J., Roos, R., & Furnell, S. (2022). Evaluation of contextual and game-based training for phishing detection. *Future Internet, 14*(104), 1-16. https://doi.org/10.3390/fi14040104

Kshetri, N., & Alcantara, L. (2015). Cyber-threats and cybersecurity challenges: A cross-cultural perspective. In N. Holden, S. Michailova, & S. Tietze (Eds.), *The Routledge Companion to Cross-Cultural Management.* Routledge. https://doi.org/10.4324/9780203798706

Lin, C., Kunnathur, A. S., & Li, L. (2020). The cultural foundation of information security behavior: Developing a cultural fit framework for information security behavior control.

Journal of Database Management, 31(2), 21-41. https://doi.org/10.4018/JDM.2020040102

Main, K., & Bottorff, C. (2023, Jun 9). *Phishing statistics by state In 2025*. Forbes Advisor. https://www.forbes.com/advisor/business/phishing-statistics/

McKnight, Z. S., & Warkentin, M. (2020). Information security compliance regarding security culture, job satisfaction, and perceived organizational support. *WISP 2020 Proceedings, 10*, 1-17. https://aisel.aisnet.org/wisp2020/10

McManus, S. (2025, Feb 04). *Why employees smuggle AI into work*. BBC. https://www.bbc.com/news/articles/cn7rx05xg2go

Morgan, J. (2023). *The role of big tech in providing cybersecurity to end users: A qualitative case study.* Northcentral University ProQuest Dissertations & Theses.

Nasir, S. (2023). Exploring the effectiveness of cybersecurity training programs: Factors, best practices, and future directions. *Advances in Multidisciplinary & Scientific Research, 2*(1), 151-160. https://doi.org/10.22624/AIMS/CSEAN-SMART2023P18

Obadofin, D. (2023). *The influence of information security awareness training on information security policy compliance among employees of the U.S. retail industry.* Capella University ProQuest Dissertations & Theses. https://www.proquest.com/docview/2903792364

Ofoegbu, K., Osundare, O. S., Ike, C. S., & Fakeyede, O. G. (2023, Dec). Enhancing cybersecurity resilience through real-time data analytics and user empowerment strategies. *Engineering Science & Technology Journal, 4*(6), 689-706. https://doi.org/10.51594/estj.v4i6.1527

Przymus, Z., Malagocka, K., & Przybyszewski, K. (2024). The human factor in cybersecurity: From risk profiles to resilience. *Procedia Computer Science, 246*, 1437-1445. https://doi.org/10.1016/j.procs.2024.09.587

Raineri, E. M., & Resig, J. (2020). Evaluating self-efficacy pertaining to cybersecurity for small businesses. *The Journal of Applied Business and Economics, 22*(12), 13-23. https://doi.org/10.33423/jabe.v22i12.3876

Reddy, D., & Dietrich, G. (2017). Cybersecurity training and the end-user: Pathways to compliance. *Journal of The Colloquium for Information System Security Education (CISSE), 5*(1), 1-24. https://cisse.info/journal/index.php/cisse/article/view/71/CISSE_v05_i01_p05.pdf

Reeves, A., Delfabbro, P., & Calic, D. (2021). Encouraging employee engagement with cybersecurity: How to tackle cyber fatigue. *SAGE Open, 11*(1), 1-18. https://doi.org/10.1177/21582440211000049

San Nicolas-Rocca, T., & Olfman, L. (2013). End user security training for identification and access management. *Journal of Organizational and End User Computing, 25*(4), 75-103. https://doi.org/10.4018/joeuc.2013100104

Shah, M. U., Iqbal, F., Rehman, U., & Hung, P. C. (2023). A comparative assessment of human factors in cybersecurity: Implications for cyber governance. *IEEE Access, 11*, 87970-87984. https://doi.org/10.1007/s10799-015-0252-2

Spivey, T. D., & McIlveene, T. R. (2024). Navigating the shadows: a comprehensive framework for anticipating, identifying, and managing shadow IT. *ISACA Journal, 6*, 33-35.

Taherdoost, H. (2024a). A critical review on cybersecurity awareness frameworks and training models. *Procedia Computer Science, 235*, 1649-1663. https://doi.org/10.1016/j.procs.2024.04.156

Taherdoost, H. (2024b). Towards an innovative model for cybersecurity awareness training. *Information, 15*(9), 512. https://doi.org/10.3390/info15090512

Tang, M., Li, M., & Zhang, T. (2016, Jun). The impacts of organizational culture on information security culture: a case study. *Information Technology and Management, 17*(2), 179-186. https://doi.org/10.1007/s10799-015-0252-2

Triplett, W. J. (2022). Addressing human factors in cybersecurity leadership. *Journal of Cybersecurity and Privacy, 2*(3), 573-586. https://doi.org/10.3390/jcp2030029

Willison, R., & Warkentin, M. (2013). Beyond deterrence: An expanded view of employee computer abuse. *MIS Quarterly, 37*(1), 1-20. https://doi.org/10.25300/MISQ/2013/37.1.01

Winkfield, M. A. (2020). *Information systems security leadership: An empirical study of behavioral influences of leaders on employees' security compliance.* ProQuest Dissertations & Theses.

Workman, M. D. (2021). An exploratory study of mode efficacy in cybersecurity training. *Journal of Cybersecurity Education, Research & Practice, 2021*(1). https://doi.org/10.62915/2472-2707.1075

APPENDICES

Appendix A: Human-Centric IS and Cybersecurity Resilience Framework

Building on the literature's emphasis that an employee's behavior often defines the success or failure of an organization's security strategy (Haney & Lutters, 2020; Willison & Warkentin, 2013), this framework consolidates seven distinct but interdependent domains. Rather than functioning as isolated initiatives, each section addresses a key component of a unified, human-centric IS and cybersecurity strategy. By implementing these sections sequentially, organizations can effectively integrate technical controls, culturally aligned policies, and adaptive training methods to create a resilient security culture (Nasir, 2023; Shah et al., 2023).

Domain 1: Leadership Engagement and Cultural Diagnosis

Role in the Framework.

This section anchors the broader security effort by ensuring that leadership visibly endorses IS and cybersecurity objectives, and that they understand how employee attitudes and norms may support or undermine these goals (Lin et al., 2020; Triplett, 2022). When leadership sets a consistent tone, employees are more likely to accept and practice secure behaviors in their daily routines.

Implementation Steps.

- Establish Leadership Sponsorship
    - Present concise risk assessments highlighting how human factors contribute to breaches (Haney & Lutters, 2020).
    - Obtain a leadership-level mandate affirming the organization's commitment to a long-term, human-centric approach.
- Conduct a Cultural Review

    - Gather feedback from multiple departments to identify whether employees view security as integral, bureaucratic, or burdensome (Spivey & McIlveene, 2024).
    - Identify operational pressures, such as speed or cost efficiency, that may conflict with adherence to security policies.
    - See: Appendix B: Framework for Auditing IS and Cybersecurity Culture
- Communicate the Vision
    - Issue a formal statement from organizational leadership emphasizing that maintaining security is an organizational priority and is tied to the organization's core values (Amankwa et al., 2022).
    - Host department-level meetings or town halls to clarify expectations, address questions, and emphasize leadership's ongoing role in modeling secure behaviors.

Domain 2: Role-Specific Risk Assessment

Role in the Framework.

Since different roles face different threat scenarios, this section ensures that mitigation trainings are tailored to actual operational needs (Kävrestad et al., 2022). By classifying teams according to data sensitivity and access privileges, organizations can allocate resources and training efforts more effectively (Taherdoost, 2024b).

Implementation Steps.

- Map Critical Assets to Departments
    - Identify core business processes, sensitive datasets, and systems (Alotaibi et al., 2019).

    - Link each asset to the departments and staff responsible for handling it.
- Conduct Targeted Risk Analyses
    - Evaluate department-specific vulnerabilities, such as finance encountering payment card data subject to PCI DSS, or healthcare units dealing with ePHI under HIPAA (Haney & Lutters, 2020).
    - Prioritize high-risk roles, such as system administrators or frontline staff managing sensitive data, for immediate security measures.
- Apply Controls and Resources
    - Provide multi-factor authentication, strict access controls, or additional monitoring where the asset and role intersection poses the most significant liability (Shah et al., 2023).
    - Document risk assignments in alignment with frameworks like ISO/IEC 27001 or NIST CSF "Identify" to facilitate compliance assessments.

Domain 3: Culturally Aligned Policy Integration

Role in the Framework.

Introducing policies that fit together with existing work norms significantly lowers the odds of employee pushback or dangerous workarounds (D'Arcy et al., 2009; Willison & Warkentin, 2013). When employees view guidelines as an extension of their existing procedures and practices, they are more likely to adopt and consistently perform secure behaviors (Lin et al., 2020).

Implementation Steps.

- Draft and Revise IS and Cybersecurity Policies Collaboratively

    - Invite representatives from multiple departments to assist with developing procedures, capturing real-life workflows and constraints (Alnajim et al., 2023).
    - Align policy language with the organization's cultural themes, such as innovation or customer care (Reddy & Dietrich, 2017).
- Emphasize Relevance and Benefits
    - Demonstrate how policies safeguard patient confidentiality (in healthcare) or maintain financial trust (in banking) (Alotaibi et al., 2019).
    - Integrate references to industry standards and compliance requirements, like GDPR or PCI DSS, to reinforce legal and ethical requirements.
- Set Consistent Leadership Examples
    - Require managers to comply with their own directives actively, demonstrating how to handle data securely or escalate potential incidents (Ani et al., 2019).
    - Publicly recognize when leadership follows protocol, signaling that compliance applies equally across all levels of the organization.

Domain 4: Interactive, Targeted Training

Role in the Framework.

A targeted training approach acknowledges that employees handling highly sensitive tasks face different risks than those in general service roles (Carreiro et al., 2024; Kävrestad et al., 2022). This section encourages deep engagement, ensuring that users receive relevant, memorable lessons tailored to their specific threat profiles (Taherdoost, 2024a).

Implementation Steps.

- Segment Training by Role and Risk

    - Provide fundamental awareness modules to all staff, followed by more advanced simulations for IT administrators or financial teams (Haney & Lutters, 2020).
    - Implement gamified exercises, interactive quizzes, or AR/VR simulations for high-risk groups where real-time practice can significantly reduce policy infractions (Donkeal Chandrashekar et al., 2024).
- Incorporate Real-Time Feedback
    - Embed instant prompts that correct users who click suspicious links in simulation exercises (Chockalingam et al., 2021).
    - Offer context-based micro-trainings triggered when an employee attempts to access sensitive systems or share restricted data (Kävrestad, 2022).
- Track and Analyze Training Outcomes
    - Collect metrics on phishing click rates, quiz performance, and user-reported incidents (Obadofin, 2023).
    - Correlate improvements with specific interventions, refining content to address identified knowledge gaps.

Domain 5: Sustained Behavioral Reinforcement

Role in the Framework.

Security awareness must be nurtured and re-emphasized to counter the natural decline that often follows a single training session (Reddy & Dietrich, 2017; Willison & Warkentin, 2013). Periodic interventions reinforce what employees learned and help them remain vigilant, especially in the face of emerging threats (Kävrestad et al., 2022).

Implementation Steps.

- Implement Scheduled Simulations and Refreshers
    - Conduct monthly or quarterly phishing tests with different attack vectors (Haney & Lutters, 2020).
    - Provide short "just-in-time" refreshers around major organizational changes, such as for new software deployments.
- Offer Rewards and Recognition
    - Celebrate employees or departments with outstanding detection rates or prompt incident reporting (Amankwa et al., 2022).
    - Reinforce positive outcomes, such as when an entire team catches a sophisticated phishing attack, to build a collective sense of achievement.
- Monitor and Adapt Reinforcements
    - Gather employee feedback on the frequency and perceived relevance of reminders or drills (Spivey & McIlveene, 2024).
    - Adjust training intervals or intensity to maintain engagement without causing fatigue or dismissiveness (Taherdoost, 2024b).

Domain 6: Adaptive Feedback and Alert Fatigue Mitigation

Role in the Framework.

Although regular reinforcement is crucial, saturating employees with constant drills or alarmist messaging can trigger complacency and diminish responsiveness (Almansoori et al., 2023). Adaptive approaches ensure that content remains fresh, aligned with shifting threats, and carefully paced to maintain effectiveness (Reeves et al., 2021).

Implementation Steps.

- Dynamic Threat Scenarios
    - Rotate simulated attacks using phishing, social engineering calls, and malicious document attachments to cover a broad range of tactics (Haney & Lutters, 2020).
    - Adjust challenge levels based on user performance history, raising or lowering difficulty to match proficiency.
- Personalize Training Progression
    - Use data analytics to classify employees as high-performers or frequent clickers and adapt their training path accordingly (Reddy & Dietrich, 2017).
    - Provide supplemental lessons for those who consistently struggle, ensuring they receive focused support.
- Solicit and Incorporate User Feedback
    - Encourage employees to report training redundancy or obsolescence (Chockalingam et al., 2021).
    - Periodically update content to provide new phishing lures or new compliance requirements so training and testing remain relevant.

Domain 7: Ongoing Governance, Auditing, and Improvement

Role in the Framework.

To maintain a strong security posture over time, organizations must periodically evaluate the effectiveness of these policies and training methodologies and identify any shifts in organizational culture (Lin et al., 2020; Shah et al., 2023). Regular governance review and

calibration ensures that emerging risks, organizational changes, or new regulations do not erode security gains.

Implementation Steps.

- Form a Cross-Functional Oversight Group
    - Assemble a team representing IT, HR, compliance, and other frontline employee groups that convenes to review security incident logs, user feedback, and training results (Obadofin, 2023).
    - Report audit findings and recommended improvements to leadership teams, reinforcing continued sponsorship.
- Conduct Third-Party Audits and Certifications
    - Align internal controls with applicable frameworks such as ISO/IEC 27001, SOC2, or PCI DSS (Alohali et al., 2018) as is required by the nature of the organization's business operations.
    - Use external audits to verify compliance, show transparency, and discover blind spots that internal audits may have missed.
- Iterate and Refine
    - Integrate new findings, like shifting threat trends, changes in or new regulations, or employee skill progress, into updated policy language and training materials (Tang et al., 2016).
    - Periodically review cultural alignment to ensure security continues to naturally integrate with evolving work processes and strategic plans (Alotaibi et al., 2019).

Summary

These seven domains offer a holistic framework for building, deploying, and iteratively refining a human-centered IS and cybersecurity program. By combining leadership involvement, policy-driven by culture, targeted training, and sustained feedback and reinforcement processes, organizations can effectively bridge the human factor gap between technical defenses and employee behaviors that ultimately sustain them (Nasir, 2023; Reeves et al., 2021). This framework lays-out an evidence-based strategy that organizations of any size can utilize to promote, support, and embed secure habits into their organizational culture and everyday activities.

Appendix B: Framework for Auditing IS and Cybersecurity Culture

This framework provides a straightforward approach to evaluating how employees understand and engage with information systems (IS) and cybersecurity practices. Each part of the framework contains a set of straightforward questions, which employees are to answer using a 5-point Likert scale. The scale ranges from 1, indicating a low or less favorable range, to 5, indicating a high or more favorable range. Then, for a deeper understanding, employees are asked to answer some open-ended questions.

The goal is to gather both quantitative (through the 1–5 ratings) and qualitative (through free-text comments) data. Each question is followed by guidance on how to interpret the scores and recommendations for actions that may help raise the score if it is trending low.

Section 1: Leadership and Management Commitment

Evaluate the degree to which leadership visibly supports, communicates, and exemplifies security-conscious behaviors.

Question 1.

"How often do you observe senior leadership or team leads proactively demonstrating or discussing secure practices?"

- Likert Scale (1–5):
    - 1 = Never
    - 5 = Consistently, in nearly all interactions
- Data Gathered:
    - This measures the visibility and consistency of leadership's security behaviors.
    - A high average score (4–5) indicates a strong leadership commitment that employees notice regularly.

  - A lower average (1–2) suggests minimal or inconsistent leadership involvement.
- Interpretation & Actions:
  - If Scores Are Low (1–2): Leaders may need explicit training on modeling secure actions or more frequent communication about security priorities (e.g., staff meetings, internal newsletters).
  - If Scores Are Moderate (3): Leadership demonstrates some visible actions but could strengthen consistency, for instance by referencing security goals in routine updates.
  - If Scores Are High (4–5): Reinforce existing behaviors and encourage leaders to share success stories or near-miss incidents to maintain momentum.
- Open-Ended Follow-Up:
  - "Please share an example (if any) where a manager's actions influenced your security habits."

Question 2.

"Do you feel upper management integrates cybersecurity considerations into overall strategic decisions?"

- Likert Scale (1–5):
  - 1 = Not at all
  - 5 = Thoroughly and consistently
- Data Gathered:
  - This assesses how well employees believe senior leaders prioritize cybersecurity in broader organizational planning (budgeting, resource allocation, etc.).

- Interpretation & Actions:
    - Low Scores (1–2): Consider adding cybersecurity targets to corporate key performance indicators. Leadership can highlight data protection goals at the same level as other strategic initiatives.
    - Moderate Scores (3): Management may discuss cybersecurity irregularly. Scheduling periodic strategy reviews specifically about security can shift this higher.
    - High Scores (4–5): Maintain open channels so employees continue to see that cybersecurity is integral to operational and strategic decisions.
- Open-Ended Follow-Up:
    - "Can you describe any strategic decisions (e.g., launching a new product or service) where cybersecurity was a clear factor?"

Section 2: Policy and Procedure Alignment

Determine whether employees find organizational security policies practical, understandable, and aligned with everyday tasks and values.

Question 1.

"How well do current IS and cybersecurity policies align with your daily work processes?"

- Likert Scale (1–5):
    - 1 = They often conflict with my tasks
    - 5 = They perfectly fit and support my tasks
- Data Gathered:

  - Indicates the extent to which employees perceive security rules as helpful or disruptive in their routine duties.
- Interpretation & Actions:
  - Low Scores (1–2): Policies may be overly restrictive or poorly communicated. Engage employees in policy reviews or form a cross-functional committee to adjust procedures.
  - Moderate Scores (3): Minor conflicts exist; consider clarifications or brief training to bridge knowledge gaps.
  - High Scores (4–5): Policies seem well-integrated. Reinforce with ongoing feedback loops to keep them updated and relevant.
- Open-Ended Follow-Up:
  - "Which part of any security policy do you find most difficult to implement in your role?"

Question 2.

"How clear are the instructions for handling sensitive data (e.g., encryption, access control) in the official policies?"

- Likert Scale (1–5):
  - 1 = Very unclear or confusing
  - 5 = Extremely clear and easy to follow
- Data Gathered:
  - Reflects how effectively the organization communicates data-protection rules.
- Interpretation & Actions:

  - Low Scores (1–2): Revise policy language for clarity; offer department-focused demonstrations or job aids showing data-handling best practices.
  - Moderate Scores (3): Some employees may understand, but the organization can create quick-reference guidelines or micro-tutorials.
  - High Scores (4–5): Current clarity is strong. Encourage new hires or teams to reference these policies regularly.
- Open-Ended Follow-Up:
  - "Describe a time when you weren't sure how to protect information in your day-to-day duties."

Section 3: Training and Education

Assess how employees perceive the frequency, format, and usefulness of existing training programs that aim to enhance security awareness.

Question 1.

"How effective is the current cybersecurity training in helping you recognize and respond to evolving threats?"

- Likert Scale (1–5):
  - 1 = Not effective at all
  - 5 = Extremely effective and up-to-date
- Data Gathered:
  - Indicates employee confidence in training content's relevance and practical value.
- Interpretation & Actions:
  - Low Scores (1–2): Training may be too generic or outdated. Revamp modules to include scenario-based or gamified elements.

    - Moderate Scores (3): Training covers the basics. Offer more role-specific sessions or refresh materials more often.
    - High Scores (4–5): Reinforce current approach; consider occasional advanced simulations to keep employees engaged.
- Open-Ended Follow-Up:
    - "What changes would make the training more applicable to your daily responsibilities?"

Question 2.

"Does the frequency of refresher training (e.g., monthly, quarterly) help maintain your awareness without causing fatigue?"

- Likert Scale (1–5):
    - 1 = There are too few sessions to remember anything
    - 5 = The current frequency is ideal (I remain alert without burnout)
- Data Gathered:
    - Measures how well the organization balances continuous learning with preventing 'alert fatigue.'
- Interpretation & Actions:
    - Low Scores (1–2): Increase the cadence of shorter, more targeted sessions. Offer micro-learning modules or quick quizzes at intervals.
    - Moderate Scores (3): Some employees may struggle with timing. Poll staff on preferred intervals and adjust training schedules accordingly.
    - High Scores (4–5): Keep the pace stable and consider adding variety, such as interactive workshops or new scenario-based exercises.

- Open-Ended Follow-Up:
    - "If you feel fatigued by the IS and cybersecurity training, what changes in content or scheduling might keep it interesting?"

Section 4: Communication and Reporting Channels

Explore how employees share concerns, near-misses, or suspected breaches, and how management reacts to such reports.

Question 1.

"How comfortable do you feel reporting a potential security risk (e.g., suspicious email) to your manager or IT security team?"

- Likert Scale (1–5):
    - 1 = Very uncomfortable
    - 5 = Very comfortable
- Data Gathered:
    - Shows the degree of psychological safety employees experience regarding security-related communications.
- Interpretation & Actions:
    - Low Scores (1–2): Employees may fear blame or punishment. Implement a "no reprisal" reporting policy. Encourage managers to thank staff who report issues.
    - Moderate Scores (3): Some reservations exist. Provide easy, perhaps anonymous, channels for reporting concerns and ensure prompt feedback.
    - High Scores (4–5): Staff trust the system. Maintain that trust with consistent, transparent responses to reports.
- Open-Ended Follow-Up:

  - "Is there anything that would make you more willing or quicker to raise a security-related concern?"

Question 2.

"How promptly and helpfully does the security or IT team respond when you report an issue?"

- Likert Scale (1–5):
  - 1 = Not at all prompt/helpful
  - 5 = Extremely prompt/helpful
- Data Gathered:
  - Reflects service quality and responsiveness from the support teams.
- Interpretation & Actions:
  - Low Scores (1–2): Response processes need overhaul; consider a ticketing system with clear deadlines or dedicated incident-response training.
  - Moderate Scores (3): Sporadic issues. Implement regular check-ins to handle common bottlenecks or improve staff coverage.
  - High Scores (4–5): Positive engagement. Continue ensuring follow-up to reinforce user confidence in the process.
- Open-Ended Follow-Up:
  - "Share any improvements that would help the IT/security team address your concerns more effectively."

Section 5: Attitudes, Motivation, and Norms

Examine the underlying cultural forces, including peer influence and individual motivation, that affect security habits.

Question 1.

"How strongly do you and your colleagues believe in following security procedures (e.g., data encryption, safe password practices) even when under tight deadlines?"

- Likert Scale (1–5):
    - 1 = Very little; shortcuts are common
    - 5 = Very strongly; we uphold security norms consistently
- Data Gathered:
    - Captures how group norms and time pressures influence willingness to comply with policies.
- Interpretation & Actions:
    - Low Scores (1–2): Deadlines or convenience override secure practices. Reevaluate workload or emphasize leadership modeling.
    - Moderate Scores (3): Mixed attitudes. Acknowledge productivity demands but provide tools or streamlined processes so security is simpler to maintain.
    - High Scores (4–5): Collective commitment is high. Continue reinforcing it with supportive leadership and recognition.
- Open-Ended Follow-Up:
    - "Describe a situation where security was compromised or upheld due to deadline or productivity pressure."

Question 2.

"What motivates you the most to maintain secure behaviors (e.g., organizational reputation, personal ethics, fear of breaches, rewards)?"

- Likert Scale (1–5):

  - 1 = No motivation
  - 5 = Extremely motivated by clear rewards or strong personal conviction
- Data Gathered:
  - Reveals internal and external motivation factors that drive security adherence.
- Interpretation & Actions:
  - Low Scores (1–2): Employees lack clear incentives or a sense of responsibility. Introduce tangible recognition programs or highlight real-life breach consequences.
  - Moderate Scores (3): Partial motivation; link security outcomes to departmental or personal goals.
  - High Scores (4–5): Leverage strong motivation by involving these employees in mentorship or advocacy roles.
- Open-Ended Follow-Up
  - "What additional incentive or support could further encourage you to protect data and systems?"

Section 6: Continuous Improvement and Feedback Loops

Determine how well the organization adapts to changing threats, collects feedback, and updates policies, procedures, and training programs.

Question 1.

"How regularly are you informed about updates to policies or emerging threats (e.g., new phishing tactics)?"

- Likert Scale (1–5):
  - 1 = Rarely; I'm often unaware of changes

    - 5 = Very regularly; I receive timely updates
- Data Gathered:
    - Gauges transparency and responsiveness to evolving security challenges.
- Interpretation & Actions:
    - Low Scores (1–2): Information flow is poor. Implement newsletters, bulletins, or real-time alerts on relevant changes.
    - Moderate Scores (3): Some updates are provided. Automate or schedule reminders to keep staff aware.
    - High Scores (4–5): Strong awareness. Continue offering short briefings or updated training modules linked to real-world incidents.
- Open-Ended Follow-Up:
    - "Which communication method (e.g., email bulletins, chat channels, short videos) helps you keep track of new threats most easily?"

Question 2.

"Do you believe the organization acts on employee feedback to improve existing cybersecurity measures?"

- Likert Scale (1–5):
    - 1 = Never; feedback rarely leads to changes
    - 5 = Always; I see frequent improvements based on user input
- Data Gathered:
    - Determines if staff feel their suggestions shape security initiatives, promoting a sense of ownership.
- Interpretation & Actions:

  - Low Scores (1–2): Suggestion processes might be too rigid or non-transparent. Create a user-friendly platform for submitting ideas and publicize results.
  - Moderate Scores (3): Some changes occur, but employees need clearer updates about action taken. Provide brief "You spoke, we listened" summaries.
  - High Scores (4–5): Employees see real impact from their feedback. Maintain and expand feedback loops, possibly forming employee working groups.
- Open-Ended Follow-Up:
  - "Can you share a specific instance where user feedback resulted in a meaningful security adjustment?"

Section 7: Observational and Follow-Up Mechanisms

Gather insights on how the organization measures compliance, tracks incident trends, and integrates lessons learned from real incidents into ongoing practice.

Question 1.

"How frequently do you or your team review security metrics (e.g., phishing click rates, unauthorized software use) or discuss security performance?"

- Likert Scale (1–5):
  - 1 = Never
  - 5 = Regularly (e.g., monthly or quarterly)
- Data Gathered:
  - Identifies whether the organization systematically monitors and discusses security indicators.
- Interpretation & Actions:

  - Low Scores (1–2): Minimal or inconsistent performance tracking. Establish routine check-ins or dashboards.
  - Moderate Scores (3): Basic metrics collection but limited collaboration. Encourage cross-department reviews for deeper insights.
  - High Scores (4–5): Metrics drive continuous improvements. Keep refining the process and make data easily accessible to all relevant stakeholders.
- Open-Ended Follow-Up:
  - "What additional metrics or statistics would help your team stay proactive about security issues?"

Question 2.

"How effective is the organization at analyzing incidents or near-misses and applying those lessons to prevent recurrences?"

- Likert Scale (1–5):
  - 1 = Not effective at all
  - 5 = Highly effective; lessons learned are quickly integrated
- Data Gathered:
  - Reflects whether the organization transforms negative events into teachable moments and procedural upgrades.
- Interpretation & Actions:
  - Low Scores (1–2): Incidents may be shrugged off or hidden. Implement a formal post-incident analysis process and widely share findings.
  - Moderate Scores (3): Some lessons learned, but not consistently applied. Assign accountability to ensure follow-through on improvements.

    - High Scores (4–5): Strong culture of continuous improvement. Keep refining by soliciting employee feedback on how changes are working.

- Open-Ended Follow-Up:
    - "Describe a recent incident that prompted a change in security procedures or training. How was it communicated?"

Using This Framework

- Data Collection
    - Likert-Scale Ratings: Provide quantitative measures to identify trends and compare across teams or over time.
    - Open-Ended Responses: Offer qualitative depth, clarifying why participants chose a particular rating and how they think improvements can be made.
- Interpreting the Results
    - Trends and Averages: Look for low or moderate trends across multiple sections. These are key pain points (e.g., weak leadership visibility or unclear policies).
    - Patterns of Strength: Repeated high scores in certain areas reveal proven practices worth sharing across the organization.
- Developing Action Plans
    - Focus on questions with average scores of 3 or below. Identify specific solutions, such as revised policy language, updated training modules, or leadership-driven communication campaigns.
    - Revisit the framework periodically (e.g., semi-annually) to gauge progress, track shifts in employee perceptions, and adapt to new threats.
- Maintaining Engagement

- Share overall findings with employees. Transparency promotes trust and shows that their feedback leads to tangible organizational changes.
- Publicize “quick wins” and recognize improvements. This encourages continued participation and motivates staff to uphold secure practices.

Summary

Organizations can develop a comprehensive understanding of their IS and cybersecurity culture by administering and analyzing this core set of questions consistently. The actionable recommendations provided for each question, along with the open-ended insights, help pinpoint where leadership, policy, training, or communication might need attention, ensuring sustained progress toward a robust and proactive security environment.

Appendix C: Permission to Quote or Reproduce Copyrighted Material

Date: April 20, 20205

I, Michael James Babcock, the owner of the copyright to the work known as *Bridging the Human Factor Gap: Fortifying Employees Through Training, Culture, and Behavioral Intervention*, hereby authorize _____ to use the following material as part of their thesis to be submitted to the American Public University System.

Page Line Number or Other Identifier

_____

Signature

Appendix D: Thesis Approval Document

School of Science, Technology, Engineering, and Math (STEM)

Master of Science in Information Technology

The thesis for the master's degree submitted by

Michael James Babcock

under the title

Bridging the Human Factor Gap: Fortifying Employees Through Training, Culture, and Behavioral Intervention

has been read by the undersigned. It is hereby recommended for acceptance by the faculty with credit to the amount of 3 semester hours.

Signed, (first reader) _____ Date:_____

Signed, (second reader, if required) _____ Date:_____

Recommended for approval on behalf of the program

Signed, _____ Date:_____

Recommendation accepted on behalf of the program director

Signed, _____ Date:_____

Approved by the academic dean

View publication stats